Question Bank — Unsolved · بنك الأسئلة (دون حلول)

Security in Computing Unsolved Question Bank

Chapters 1–3 · 563 questions · English only · no answers, no hints

Numbering matches the Solved Question Bank exactly (same question numbers). Source: Pfleeger et al., *Security in Computing*, 6th ed.; lecture slides 2026 (Dr. A. Al-Azzani)

Table of Contents

Chapter 1 — Introduction 4
- Assets, vulnerabilities, threats and controls 4
- CIA triad, harm acts and related properties 6
- Access-control terms and aspects of CIA 11
- Threats, attackers, CVE/CVSS and insiders 12
- Passive and active attacks 15
- Risk and method–opportunity–motive 17
- Attack surface and information classification 18
- Layers and controls 20
- Previous-exam questions (2015–2019) 22
- Original practice questions 24

Chapter 2.1 — Authentication 29
- Identification, authentication, factors and passwords 29
- Previous-exam questions (2015–2019) 32
- Original practice questions 34

Chapter 2.2 — Access Control 38
- Access-control concepts, policies and logs 38
- Access-control models (DAC, MAC, RBAC, ABAC, formal models) 41
- Previous-exam questions (2015–2019) 45
- Original practice questions 47

Chapter 2.3 — Cryptography 50
- Cryptography basics and terminology 50
- Classical ciphers 52
- Symmetric/asymmetric, stream/block, DES 54
- AES, confusion and diffusion 57
- RSA 59
- Hashes, digital signatures, certificates, key exchange 61
- Counting keys 64
- Cryptography/security tools 65
- Previous-exam questions (2015–2019) 66
- Original practice questions 67

Chapter 3 — Programs and Programming 71
- Program flaws and buffer overflows 71
- Mediation, reference monitor, TOCTTOU 75
- Trapdoors / backdoors 78
- Malicious code and countermeasures 79
- SSDLC and security requirements 85
- Mixed review (incl. NOT questions) 86
- Previous-exam questions (2015–2019) 88
- Original practice questions 90

Legacy Topics 95
Legacy questions from 2015-16 / 2018-19 95
Written Questions 97
Previous-exam written questions 97
Original written practice 101

About this question bank

563 questions: 530 multiple-choice and 33 written. Organised by chapter and topic, easy → hard inside each group where possible. Question numbers are identical in the unsolved and solved PDFs.

Tag	Meaning	Count
PB	PB = professor's MCQ bank (361 questions, user-supplied file) — original numbering kept in the reference	361
PE	PE = past-exam question (2015-16 … 2018-19, user-supplied scans) — wording abridged/cleaned	86
OR	OR = original practice question written for this package (not copied from any source)	116

Scope of the research and its limits

- The principal question sources are the files you supplied: the professor's 361-question MCQ bank and four past exams. These are reproduced here for your personal study, with original numbering in the source reference.
- I searched the public web for matching or similar published questions. The network policy of the work environment blocked direct access to most sites (HTTP 403), so I could read only search-engine result summaries. **I did not copy any third-party or paid question bank**, and I do not claim to have found every question available online.
- Public resources that *appeared in search results* for this textbook/topic and may be worth opening yourself: Brainscape decks "Chapter 2: Toolbox: Authentication, Access Control, and Cryptography" (`brainscape.com/flashcards/chapter-2-toolbox-authentication-access-13951096/packs/21556990` and `…-9920127/packs/17662705`); the publisher page for the 6th edition (`pearson.com/store/p/security-in-computing/P200000009559/9780137891252`); the O'Reilly table of contents for Chapter 2 (`oreilly.com/library/view/security-in-computing/9780137891375/ch02.xhtml`). Their contents were not verified.
- Original (OR) questions were written to cover gaps and the recurring patterns in the past exams (calculations for RSA/Caesar/key counts, scenarios, essay recipes).
- A few past-exam questions are ambiguous or lie outside the 2026 slides; they are flagged with a confidence level in the solved edition. One past question (maturity-model level) was excluded because its answer could not be verified.

Chapter 1 — Introduction

Assets, vulnerabilities, threats and controls

1. What is the primary purpose of information security?

A. To increase computer speed
B. To protect information and information systems
C. To create software applications
D. To increase storage capacity

[PB] Professor's MCQ bank (user-supplied file), original Q1 · Difficulty: Easy

2. Which of the following is considered an information asset?

A. Hardware only
B. Software only
C. Data only
D. Hardware, software, data, people, and processes

[PB] Professor's MCQ bank (user-supplied file), original Q2 · Difficulty: Easy

3. Which statement about the value of an asset is correct?

A. It must always be monetary
B. It never changes
C. It can be subjective and time-dependent
D. Only hardware has value

[PB] Professor's MCQ bank (user-supplied file), original Q3 · Difficulty: Easy

4. Information security protects information in:

A. Digital form only
B. Printed form only
C. All forms and formats
D. Network form only

[PB] Professor's MCQ bank (user-supplied file), original Q4 · Difficulty: Easy

5. Cybersecurity primarily focuses on protecting:

A. Only paper documents
B. Digital assets and interconnected systems
C. Office furniture
D. Printed books only

[PB] Professor's MCQ bank (user-supplied file), original Q5 · Difficulty: Easy

6. According to the chapter, cybersecurity is:

A. Completely unrelated to information security
B. A part of information security
C. Only physical security
D. Only personnel security

[PB] Professor's MCQ bank (user-supplied file), original Q6 · Difficulty: Easy

7. The Principle of Easiest Penetration states that an attacker:

A. Always attacks the strongest point
B. Attacks only through the Internet
C. May exploit any available means to penetrate a system
D. Must physically enter the organization

[PB] Professor's MCQ bank (user-supplied file), original Q7 · Difficulty: Easy

8. Which of the following is NOT necessarily an information asset?

A. Data
B. Software
C. People
D. None of the above

[PB] Professor's MCQ bank (user-supplied file), original Q8 · Difficulty: Medium

9. What is a vulnerability?

A. A protective measure
B. A weakness in a system
C. A completed attack
D. A security policy only

[PB] Professor's MCQ bank (user-supplied file), original Q9 · Difficulty: Easy

10. What is a threat?

A. A circumstance with the potential to cause harm
B. A security control
C. A type of password
D. A software update

[PB] Professor's MCQ bank (user-supplied file), original Q10 · Difficulty: Easy

11. What is a security control?

A. A weakness in a system
B. An attacker
C. A protective measure that reduces or removes a vulnerability
D. A harmful event

[PB] Professor's MCQ bank (user-supplied file), original Q11 · Difficulty: Easy

12. Which of the following best describes an attacker?

A. A person who only creates security policies
B. A human who exploits a vulnerability
C. A hardware component
D. A security control

[PB] Professor's MCQ bank (user-supplied file), original Q12 · Difficulty: Easy

13. Which relationship is correct?

A. A control creates a vulnerability
B. A vulnerability always eliminates a threat
C. A threat may exploit a vulnerability, while a control helps protect against it
D. A threat and a control mean the same thing

[PB] Professor's MCQ bank (user-supplied file), original Q13 · Difficulty: Easy

14. Which of the following is an example of a vulnerability?

A. A properly configured firewall
B. A weak authentication mechanism
C. An encrypted database
D. A security guard

[PB] Professor's MCQ bank (user-supplied file), original Q14 · Difficulty: Easy

15. A threat is best described as:

A. The weakness itself
B. The protective measure
C. A condition that could exercise a vulnerability
D. The value of an asset

[PB] Professor's MCQ bank (user-supplied file), original Q15 · Difficulty: Easy

CIA triad, harm acts and related properties

16. What are the three main principles of the CIA Triad?

A. Control, Identification, Authentication
B. Confidentiality, Integrity, Availability
C. Cybersecurity, Internet, Access
D. Classification, Investigation, Authorization

[PB] Professor's MCQ bank (user-supplied file), original Q16 · Difficulty: Easy

17. Confidentiality means that information is accessed by:

A. Everyone
B. Authorized parties only
C. Attackers only
D. Administrators only, in all cases

[PB] Professor's MCQ bank (user-supplied file), original Q17 · Difficulty: Easy

18. Which action primarily threatens confidentiality?

A. Unauthorized reading of a file
B. Deleting a file
C. Changing a database record
D. Making a server unavailable

[PB] Professor's MCQ bank (user-supplied file), original Q18 · Difficulty: Easy

19. Integrity means that information is:

A. Always publicly available
B. Modified only in authorized ways
C. Accessible to every user
D. Never stored electronically

[PB] Professor's MCQ bank (user-supplied file), original Q19 · Difficulty: Easy

20. Which action primarily threatens integrity?

A. Unauthorized modification of a database
B. Reading a public document
C. Viewing an authorized report
D. Printing an authorized file

[PB] Professor's MCQ bank (user-supplied file), original Q20 · Difficulty: Easy

21. Availability means that information and services are:

A. Available only to attackers
B. Usable by authorized parties when needed
C. Always secret
D. Never modified

[PB] Professor's MCQ bank (user-supplied file), original Q21 · Difficulty: Easy

22. A Denial-of-Service attack primarily affects:

A. Confidentiality
B. Integrity
C. Availability
D. Classification

[PB] Professor's MCQ bank (user-supplied file), original Q22 · Difficulty: Easy

23. Which of the following is described in the chapter as a fourth leg of information security?

A. Privacy
B. Hardware
C. Authentication
D. Classification

[PB] Professor's MCQ bank (user-supplied file), original Q23 · Difficulty: Easy

24. Which security property confirms the identity of a sender?

A. Availability
B. Authentication
C. Integrity
D. Classification

[PB] Professor's MCQ bank (user-supplied file), original Q24 · Difficulty: Easy

25. Which property helps prevent a sender from convincingly denying that they sent a message?

A. Availability
B. Confidentiality
C. Nonrepudiation
D. Interruption

[PB] Professor's MCQ bank (user-supplied file), original Q25 · Difficulty: Easy

26. What is auditability?

A. Hiding all system activities
B. Being able to trace actions related to an asset
C. Deleting audit records
D. Allowing anonymous access

[PB] Professor's MCQ bank (user-supplied file), original Q26 · Difficulty: Easy

27. Authorization refers to:

A. Verifying a user's identity
B. Granting specific access rights to a subject
C. Creating a backup only
D. Detecting natural disasters

[PB] Professor's MCQ bank (user-supplied file), original Q27 · Difficulty: Easy

28. Which act of harm involves unauthorized access to information?

A. Interception
B. Interruption
C. Modification
D. Fabrication

[PB] Professor's MCQ bank (user-supplied file), original Q28 · Difficulty: Easy

29. Which act of harm makes an asset unavailable or unusable?

A. Fabrication
B. Modification
C. Interruption
D. Interception

[PB] Professor's MCQ bank (user-supplied file), original Q29 · Difficulty: Easy

30. Unauthorized tampering with existing data is called:

A. Interception
B. Modification
C. Interruption
D. Classification

[PB] Professor's MCQ bank (user-supplied file), original Q30 · Difficulty: Easy

31. Adding counterfeit records or transactions to a system is called:

A. Interruption
B. Interception
C. Fabrication
D. Authentication

[PB] Professor's MCQ bank (user-supplied file), original Q31 · Difficulty: Easy

32. Illicit copying of information primarily represents:

A. Interception
B. Interruption
C. Fabrication
D. Recovery

[PB] Professor's MCQ bank (user-supplied file), original Q32 · Difficulty: Easy

33. Erasing important files so that they cannot be used is an example of:

A. Interception
B. Interruption
C. Authentication
D. Nonrepudiation

[PB] Professor's MCQ bank (user-supplied file), original Q33 · Difficulty: Easy

34. Changing a transmitted message without authorization is an example of:

A. Modification
B. Interruption
C. Privacy
D. Availability

[PB] Professor's MCQ bank (user-supplied file), original Q34 · Difficulty: Easy

35. What are the three fundamental concepts of information security?

A. Authentication, Authorization, Accounting
B. Confidentiality, Integrity, Availability
C. Encryption, Decryption, Authentication
D. Privacy, Safety, Monitoring

[PB] Professor's MCQ bank (user-supplied file), original Q101 · Difficulty: Easy

36. What does confidentiality mean?

A. Ensuring information is always available
B. Preventing unauthorized disclosure of information
C. Preventing all system failures
D. Ensuring data is deleted

[PB] Professor's MCQ bank (user-supplied file), original Q102 · Difficulty: Easy

37. What does integrity protect against?

A. Unauthorized modification or destruction
B. Unauthorized reading only
C. Power failure only
D. Network congestion only

[PB] Professor's MCQ bank (user-supplied file), original Q103 · Difficulty: Easy

38. What does availability ensure?

A. Only authorized users can read information
B. Information cannot be modified
C. Timely and reliable access to information
D. All information is encrypted

[PB] Professor's MCQ bank (user-supplied file), original Q104 · Difficulty: Easy

39. Which security objective prevents unauthorized disclosure?

A. Availability
B. Integrity
C. Confidentiality
D. Accounting

[PB] Professor's MCQ bank (user-supplied file), original Q118 · Difficulty: Easy

40. Which security objective is concerned with improper modification or destruction of information?

A. Integrity
B. Availability
C. Identification
D. Authentication

[PB] Professor's MCQ bank (user-supplied file), original Q119 · Difficulty: Easy

41. Which security objective ensures reliable access when needed?

A. Confidentiality
B. Availability
C. Cryptanalysis
D. Encryption

[PB] Professor's MCQ bank (user-supplied file), original Q120 · Difficulty: Easy

Access-control terms and aspects of CIA

42. In access control, a subject is:

A. The resource being accessed
B. The entity requesting access
C. The access policy
D. The security device

[PB] Professor's MCQ bank (user-supplied file), original Q35 · Difficulty: Easy

43. In access control, an object is:

A. The resource being accessed
B. The person who writes the policy
C. The attacker only
D. The authentication method

[PB] Professor's MCQ bank (user-supplied file), original Q36 · Difficulty: Easy

44. Which of the following is an access mode?

A. Read
B. Write
C. Execute
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q37 · Difficulty: Easy

45. An access control policy specifies:

A. Who can access what and how
B. Only the color of the user interface
C. The price of hardware
D. The size of a database

[PB] Professor's MCQ bank (user-supplied file), original Q38 · Difficulty: Easy

46. The access control paradigm aims to control:

A. Only administrator access
B. Only network access
C. All accesses by all subjects to protected objects in all modes
D. Only access to printed documents

[PB] Professor's MCQ bank (user-supplied file), original Q39 · Difficulty: Easy

47. A single point of control may become a single point of failure that affects:

A. Availability
B. Classification
C. Privacy only
D. Asset value only

[PB] Professor's MCQ bank (user-supplied file), original Q40 · Difficulty: Medium

48. Which of the following is an aspect of integrity?

A. Ensuring authorized actions
B. Protecting resources from improper changes
C. Detecting and correcting errors
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q41 · Difficulty: Medium

49. Which of the following is related to availability?

A. Timely access to services
B. Sufficient system capacity
C. Fault tolerance
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q42 · Difficulty: Medium

50. What is the purpose of concurrency control?

A. To prevent all users from accessing the system
B. To manage simultaneous access to shared resources
C. To classify military information
D. To eliminate all security policies

[PB] Professor's MCQ bank (user-supplied file), original Q43 · Difficulty: Medium

Threats, attackers, CVE/CVSS and insiders

51. Which of the following is a nonhuman threat?

A. Phishing
B. Impersonation
C. Power failure
D. Malware

[PB] Professor's MCQ bank (user-supplied file), original Q44 · Difficulty: Easy

52. Which is an example of a nonmalicious human threat?

A. Deliberately destroying hardware
B. Accidentally deleting a file
C. Launching a DDoS attack
D. Installing malware intentionally

[PB] Professor's MCQ bank (user-supplied file), original Q45 · Difficulty: Easy

53. Which is an example of a malicious human threat?

A. Natural flood
B. Accidental email to the wrong recipient
C. Intentional malware installation
D. Unplanned power failure

[PB] Professor's MCQ bank (user-supplied file), original Q46 · Difficulty: Easy

54. What does CVE provide?

A. A dictionary of publicly known vulnerabilities and exposures
B. A method for encrypting all data
C. A firewall configuration
D. A physical access card

[PB] Professor's MCQ bank (user-supplied file), original Q47 · Difficulty: Easy

55. What does CVSS provide?

A. A list of employees
B. A standard system for scoring vulnerability severity
C. A backup mechanism
D. A type of malware

[PB] Professor's MCQ bank (user-supplied file), original Q48 · Difficulty: Easy

56. CVE and CVSS are:

A. Exactly the same thing
B. Two names for a firewall
C. Different concepts: vulnerability identification and vulnerability scoring
D. Both types of physical controls

[PB] Professor's MCQ bank (user-supplied file), original Q49 · Difficulty: Easy

57. What does APT stand for?

A. Advanced Protection Technology
B. Advanced Persistent Threat
C. Authorized Program Transfer
D. Automatic Password Tracking

[PB] Professor's MCQ bank (user-supplied file), original Q50 · Difficulty: Easy

58. Which characteristic is commonly associated with an APT?

A. Immediate abandonment of the target
B. Long-term, stealthy activity
C. No planning
D. No resources

[PB] Professor's MCQ bank (user-supplied file), original Q51 · Difficulty: Easy

59. Spear phishing is commonly associated with:

A. Targeted attacks
B. Physical fences
C. Power failures
D. Fire suppression systems

[PB] Professor's MCQ bank (user-supplied file), original Q52 · Difficulty: Easy

60. Nation-state-sponsored attacks are often associated with:

A. Strategic government objectives
B. Only accidental errors
C. Only personal entertainment
D. Ordinary equipment failure

[PB] Professor's MCQ bank (user-supplied file), original Q53 · Difficulty: Easy

61. Which of the following may be a goal of a nation-state-sponsored cyberattack?

A. Espionage
B. Sabotage
C. Gaining economic or military advantage
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q54 · Difficulty: Easy

62. According to the chapter, which of the following can be an attacker type?

A. An individual
B. Organized crime groups
C. Terrorists
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q55 · Difficulty: Easy

63. Which of the following is one of the four ways terrorists may use computers, according to the chapter?

A. As targets
B. As enablers
C. As methods or enhancers
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q56 · Difficulty: Easy

64. An insider threat may originate from:

A. Employees
B. Contractors
C. Suppliers
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q57 · Difficulty: Easy

65. Which of the following is an example of a weak security policy?

A. Clearly defined user permissions
B. Proper segregation of duties
C. Unclear roles and responsibilities
D. Strong authentication requirements

[PB] Professor's MCQ bank (user-supplied file), original Q58 · Difficulty: Easy

66. Which is an example of weak security administration?

A. Correctly configured systems
B. Strong administrator passwords
C. Misconfigured systems and applications
D. Restricted administrative access

[PB] Professor's MCQ bank (user-supplied file), original Q59 · Difficulty: Easy

67. Which behavior demonstrates a lack of security awareness?

A. Recognizing phishing emails
B. Sharing passwords with other people
C. Following security procedures
D. Reporting suspicious messages

[PB] Professor's MCQ bank (user-supplied file), original Q60 · Difficulty: Easy

68. What is shoulder surfing?

A. Watching someone enter sensitive information
B. Encrypting a hard drive
C. Updating an operating system
D. Reviewing a firewall log

[PB] Professor's MCQ bank (user-supplied file), original Q61 · Difficulty: Easy

69. Dumpster diving refers to:

A. Searching discarded materials for useful information
B. Encrypting discarded files
C. Monitoring network packets
D. Testing system availability

[PB] Professor's MCQ bank (user-supplied file), original Q62 · Difficulty: Easy

Passive and active attacks

70. Passive attacks primarily threaten:

A. Confidentiality
B. Availability only
C. Hardware performance only
D. Physical security only

[PB] Professor's MCQ bank (user-supplied file), original Q63 · Difficulty: Easy

71. Which is an example of a passive attack?

A. Traffic analysis
B. Deleting a database
C. Modifying a message
D. Denial of Service

[PB] Professor's MCQ bank (user-supplied file), original Q64 · Difficulty: Easy

72. Which of the following is also a passive attack?

A. Snooping
B. Fabrication
C. Interruption
D. Destruction of hardware

[PB] Professor's MCQ bank (user-supplied file), original Q65 · Difficulty: Easy

73. Active attacks may threaten:

A. Integrity
B. Availability
C. Authenticity
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q66 · Difficulty: Easy

74. Which of the following is an active attack?

A. Traffic analysis
B. Snooping
C. Replay attack
D. Passive observation only

[PB] Professor's MCQ bank (user-supplied file), original Q67 · Difficulty: Easy

75. A masquerading attack involves:

A. Pretending to be another entity
B. Making a backup
C. Installing a security patch
D. Classifying data

[PB] Professor's MCQ bank (user-supplied file), original Q68 · Difficulty: Easy

76. A repudiation attack relates to:

A. Denying an action or transaction
B. Encrypting a message
C. Preventing physical access
D. Improving availability

[PB] Professor's MCQ bank (user-supplied file), original Q69 · Difficulty: Easy

77. Which statement about passive attacks is correct according to the chapter?

A. They always modify data
B. They may be difficult to detect
C. They always destroy hardware
D. They always prevent access to services

[PB] Professor's MCQ bank (user-supplied file), original Q70 · Difficulty: Easy

78. Which statement about active attacks is correct according to the chapter?

A. They never affect system operation
B. They can change data or harm the system
C. They only observe traffic
D. They cannot affect availability

[PB] Professor's MCQ bank (user-supplied file), original Q71 · Difficulty: Easy

Risk and method–opportunity–motive

79. What is risk?

A. The possibility of harm
B. A security control
C. An information classification label
D. A type of hardware

[PB] Professor's MCQ bank (user-supplied file), original Q72 · Difficulty: Easy

80. What is residual risk?

A. Risk that existed before any security control
B. Risk remaining after controls are applied
C. Risk that can never occur
D. Risk that affects only hardware

[PB] Professor's MCQ bank (user-supplied file), original Q73 · Difficulty: Easy

81. Why is risk management necessary?

A. Because resources are unlimited
B. Because all risks can always be eliminated
C. Because organizations must prioritize protection using limited resources
D. Because security controls are never needed

[PB] Professor's MCQ bank (user-supplied file), original Q74 · Difficulty: Easy

82. Which is a key activity in risk management?

A. Assessing asset value
B. Identifying possible harm
C. Evaluating protection costs
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q75 · Difficulty: Easy

83. What does residual risk indicate?

A. That security is perfect
B. That some risk remains despite protection
C. That an asset has no value
D. That no threat exists

[PB] Professor's MCQ bank (user-supplied file), original Q76 · Difficulty: Easy

84. In attack analysis, method refers to:

A. Why the attacker acts
B. How the attacker carries out the attack
C. The asset's monetary value
D. The classification label

[PB] Professor's MCQ bank (user-supplied file), original Q77 · Difficulty: Easy

85. Opportunity refers to:

A. The attacker's reason
B. The attacker's access or chance to act
C. The value of the asset
D. The security classification

[PB] Professor's MCQ bank (user-supplied file), original Q78 · Difficulty: Easy

86. Motive refers to:

A. Why the attacker wants to act
B. The security control
C. The system's processing speed
D. The access mode

[PB] Professor's MCQ bank (user-supplied file), original Q79 · Difficulty: Easy

87. According to the chapter's method–opportunity–motive model, denying any one of these can:

A. Guarantee that every system is perfectly secure
B. Help prevent the contemplated attack
C. Increase the attacker's access
D. Remove the need for all controls

[PB] Professor's MCQ bank (user-supplied file), original Q80 · Difficulty: Medium

88. Which of the following is a common source of vulnerabilities?

A. Weak access control
B. Program errors
C. Insufficient resources
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q81 · Difficulty: Easy

Attack surface and information classification

89. What is an attack surface?

A. The complete set of actual and potential vulnerabilities that may be exploited
B. The physical surface of a computer
C. A classification policy
D. A type of encryption algorithm

[PB] Professor's MCQ bank (user-supplied file), original Q82 · Difficulty: Easy

90. Which of the following is a business information classification label?

A. Public
B. Sensitive
C. Private
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q83 · Difficulty: Easy

91. Which classification scheme includes the label Top Secret?

A. Business classification
B. Military classification
C. Traffic Light Protocol only
D. Access mode classification

[PB] Professor's MCQ bank (user-supplied file), original Q84 · Difficulty: Easy

92. Which label indicates that information is intended for public disclosure and generally has low harm if disclosed?

A. Top Secret
B. Confidential
C. Public
D. Secret

[PB] Professor's MCQ bank (user-supplied file), original Q85 · Difficulty: Easy

93. Which business classification may include trade secrets and sensitive internal company information?

A. Public
B. Confidential
C. Unclassified
D. White

[PB] Professor's MCQ bank (user-supplied file), original Q86 · Difficulty: Easy

94. Which military classification indicates that disclosure could cause serious harm to national security?

A. Unclassified
B. Secret
C. Public
D. Green

[PB] Professor's MCQ bank (user-supplied file), original Q87 · Difficulty: Easy

95. Which military classification indicates the gravest level of harm described in the chapter?

A. Unclassified
B. SBU
C. Secret
D. Top Secret

[PB] Professor's MCQ bank (user-supplied file), original Q88 · Difficulty: Easy

96. In the Traffic Light Protocol, which labels are used?

A. Public, Private, Confidential, Secret
B. White, Green, Amber, Red
C. Low, Medium, High, Critical
D. Read, Write, Execute, Delete

[PB] Professor's MCQ bank (user-supplied file), original Q89 · Difficulty: Easy

97. Which is an important step in data classification?

A. Defining classification levels
B. Identifying data owners
C. Establishing controls for each level
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q90 · Difficulty: Easy

Layers and controls

98. Which of the following is a security layer?

A. Physical
B. Hardware
C. Network
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q91 · Difficulty: Easy

99. Which of the following is also a security layer mentioned in the chapter?

A. Communications
B. Software
C. Human/personnel
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q92 · Difficulty: Easy

100. Security policies and procedures support security by:

A. Planning and implementation
B. Monitoring and auditing
C. Detection, correction, and managing changes
D. All of the above

[PB] Professor's MCQ bank (user-supplied file), original Q93 · Difficulty: Easy

101. What is the purpose of security controls?

A. To increase vulnerabilities
B. To neutralize threats or reduce vulnerabilities
C. To eliminate all information assets
D. To prevent authorized access

[PB] Professor's MCQ bank (user-supplied file), original Q94 · Difficulty: Easy

102. Which of the following is a physical control?

A. Firewall
B. Encryption
C. Security fence
D. Password policy software

[PB] Professor's MCQ bank (user-supplied file), original Q95 · Difficulty: Easy

103. Which is an example of a procedural or administrative control?

A. Security policy
B. Firewall
C. Encryption algorithm
D. Network protocol

[PB] Professor's MCQ bank (user-supplied file), original Q96 · Difficulty: Easy

104. Which of the following is a technical control?

A. A physical fence
B. Encryption
C. A written contract
D. A security guard

[PB] Professor's MCQ bank (user-supplied file), original Q97 · Difficulty: Easy

105. A firewall is an example of:

A. A technical control
B. A physical control
C. A human threat
D. An information classification level

[PB] Professor's MCQ bank (user-supplied file), original Q98 · Difficulty: Easy

106. What is defense in depth?

A. Using only one security control
B. Using overlapping controls and multiple control classes
C. Removing all security policies
D. Relying entirely on employees

[PB] Professor's MCQ bank (user-supplied file), original Q99 · Difficulty: Easy

107. Which set represents the five functions listed in the chapter for security and cybersecurity risk management?

A. Plan, Build, Sell, Test, Deploy
B. Identify, Protect, Detect, Respond, Recover
C. Read, Write, Execute, Delete, Print
D. Prevent, Ignore, Delay, Remove, Replace

[PB] Professor's MCQ bank (user-supplied file), original Q100 · Difficulty: Easy

Previous-exam questions (2015–2019)

108. A power failure is a ..... threat.

A. natural causes
B. human causes
C. benign intent
D. malicious intent

[PE] Previous exams 2016-17 & 2017-18 (Q11) · Difficulty: Easy

109. A malicious code on a general website is a ..... threat.

A. natural causes
B. benign intent
C. a & b
D. human causes

[PE] Previous exams 2016-17 & 2017-18 (Q12) · Difficulty: Easy

110. A machinicide attack applies on computer ..... asset.

A. Software
B. hardware
C. data
D. non all previous

[PE] Previous exams 2016-17 & 2017-18 (Q13) · Difficulty: Medium

111. Laws and regulations is a ..... controls.

A. technical
B. physical
C. procedural or administrative
D. a & b

[PE] Previous exams 2016-17 & 2017-18 & 2015-16 & 2018-19 (Q14/Q12) · Difficulty: Easy

112. ..... is/are aspect(s) that can enhance the effectiveness of controls.

A. awareness of problem & likelihood of use
B. physical controls
C. overlapping controls & periodic review
D. a & c

[PE] Previous exams 2016-17 & 2017-18 (Q15) · Difficulty: Medium

113. An interruption threat to the security of computing system is effected on the .....

A. Availability
B. confidentiality
C. integrity
D. authenticity

[PE] Previous exams 2016-17 & 2017-18 (Q16) · Difficulty: Easy

114. An interception threat to the security of computing system is effected on the .....

A. Availability
B. confidentiality
C. integrity
D. authenticity

[PE] Previous exams 2016-17 & 2017-18 (Q17) · Difficulty: Easy

115. A modification threat to the security of computing system is effected on the .....

A. Availability
B. confidentiality
C. integrity
D. authenticity

[PE] Previous exams 2016-17 & 2017-18 (Q18) · Difficulty: Easy

116. A fabrication threat to the security of computing system is effected on the .....

A. Availability
B. confidentiality
C. authenticity
D. all true

[PE] Previous exams 2016-17 & 2017-18 (Q19) · Difficulty: Easy

117. What type of control is intended to offset deficiencies of other controls?

A. Preventive
B. Defensive
C. Compensating
D. Recovery
E. All of the above

[PE] Previous exams 2015-16 & 2018-19 (Q2/Q2) · Difficulty: Medium

118. Privacy is a concern in which of the following industries?

A. Financial services
B. Financial services and government
C. Telecommunications
D. All of the above

[PE] Previous exams 2015-16 & 2018-19 (Q6) · Difficulty: Easy

119. What is assurance?

A. It is a type of insurance against security violations.
B. It is the written security policy.
C. It is about the trustworthiness of a system
D. It is provided by the mandatory access control (MAC)
E. All of the above

[PE] Previous exams 2015-16 & 2018-19 (Q7) · Difficulty: Medium

120. Information security policies and procedures are a(n) .....

A. Technical control
B. Administrative control
C. Form of access control
D. Operational control
E. All of the above

[PE] Previous exams 2015-16 & 2018-19 (Q8/Q8) · Difficulty: Easy

Original practice questions

121. A student leaves the laptop unlocked in a library; a stranger reads her messages. Which property is violated?

A. Availability
B. Confidentiality
C. Integrity
D. Nonrepudiation

[OR] Original practice question (written for this package) · Difficulty: Easy

122. A virus deletes a company's customer database. Which harm act and CIA property are involved?

A. Interception – Confidentiality
B. Interruption – Availability
C. Fabrication – Authenticity
D. Modification – Integrity

[OR] Original practice question (written for this package) · Difficulty: Easy

123. An attacker changes the amount in a bank transfer while it travels over the network. This is ...

A. a passive attack on confidentiality
B. an active attack on integrity
C. a denial of service
D. traffic analysis

[OR] Original practice question (written for this package) · Difficulty: Medium

124. Which statement correctly relates a threat, a vulnerability and a control?

A. A control exploits a threat to create a vulnerability
B. A threat exploits a vulnerability; a control blocks the threat by removing/reducing the vulnerability
C. A vulnerability blocks a control
D. A threat and vulnerability are the same

[OR] Original practice question (written for this package) · Difficulty: Medium

125. Which is an example of a vulnerability?

A. A flood
B. An unpatched server
C. An antivirus program
D. A hacker

[OR] Original practice question (written for this package) · Difficulty: Easy

126. The risk that remains after controls have been applied is called ...

A. inherent risk
B. residual risk
C. threat risk
D. zero risk

[OR] Original practice question (written for this package) · Difficulty: Easy

127. Order the steps of the basic risk-management model (S66).

A. Select safeguards → value assets → compute protection costs → estimate harm
B. Value assets → estimate harm from threats → compute protection costs → select safeguards
C. Estimate harm → select safeguards → value assets → ignore costs
D. Compute costs → value assets → ignore threats → select safeguards

[OR] Original practice question (written for this package) · Difficulty: Medium

128. A guard, a lock and a fence are examples of ...

A. technical controls
B. procedural controls
C. physical controls
D. compensating controls only

[OR] Original practice question (written for this package) · Difficulty: Medium

129. An organisation publishes an acceptable-use policy. This is a(n) ... control.

A. physical
B. technical
C. administrative/procedural
D. biometric

[OR] Original practice question (written for this package) · Difficulty: Easy

130. Which way of dealing with harm does a honeypot illustrate?

A. Prevent
B. Deflect
C. Recover
D. Deter

[OR] Original practice question (written for this package) · Difficulty: Medium

131. Posting a warning banner “unauthorized access will be prosecuted” mainly provides ...

A. prevention
B. deterrence
C. recovery
D. detection

[OR] Original practice question (written for this package) · Difficulty: Medium

132. Which of the following is NOT one of the NIST/ENISA five functions?

A. Identify
B. Protect
C. Encrypt
D. Recover

[OR] Original practice question (written for this package) · Difficulty: Medium

133. Information classified as “Secret” in the military scheme, if disclosed, could cause ...

A. no damage
B. minor damage
C. serious damage to national security
D. grave damage (this is Top Secret)

[OR] Original practice question (written for this package) · Difficulty: Medium

134. Which attacker type uses computers as targets, enablers, methods and enhancers?

A. Individual hackers
B. Terrorists
C. Insiders
D. Script kiddies

[OR] Original practice question (written for this package) · Difficulty: Easy

135. An attacker quietly maintains access to a victim for many months, using spear-phishing against selected employees. This describes ...

A. a script kiddie
B. an advanced persistent threat (APT)
C. a random worm
D. an accidental error

[OR] Original practice question (written for this package) · Difficulty: Medium

136. Which of these is an INTERNAL threat?

A. A storm that floods a data center
B. A disgruntled contractor copying data
C. A foreign hacker
D. A power-grid failure

[OR] Original practice question (written for this package) · Difficulty: Easy

137. A burglar needs a crowbar, an empty house at night and a reason to steal. These correspond respectively to ...

A. motive, method, opportunity

B. method, opportunity, motive

C. opportunity, motive, method

D. method, motive, opportunity

[OR] Original practice question (written for this package) · Difficulty: Medium

138. Which property allows a system to show that a sender cannot deny sending a message?

A. Auditability

B. Nonrepudiation

C. Availability

D. Privacy

[OR] Original practice question (written for this package) · Difficulty: Easy

139. Which is a failure of confidentiality?

A. A user learns that a secret file exists, without reading it

B. A database is slow

C. A file is deleted by its owner

D. A message is delivered twice

[OR] Original practice question (written for this package) · Difficulty: Medium

140. Which of the following is a typical way the availability of a service is expressed?

A. Bounded waiting time and timely response

B. Strong encryption

C. Digital signatures

D. Salted hashes

[OR] Original practice question (written for this package) · Difficulty: Medium

141. Why is a single point of access control both good and risky?

A. It is good for confidentiality/integrity but can be a single point of failure for availability

B. It is bad for confidentiality and good for availability

C. It has no effect on security

D. It always improves availability

[OR] Original practice question (written for this package) · Difficulty: Hard

142. A data custodian is the person who ...

A. sets classification levels and is ultimately responsible

B. enforces security policies on data (often IT staff)

C. uses the data day to day only

D. writes laws

[OR] Original practice question (written for this package) · Difficulty: Medium

143. The Principle of Easiest Penetration implies that ...

A. strong doors are enough

B. the weakest point is the most serious vulnerability

C. attackers always choose the strongest defence

D. only software is attacked

[OR] Original practice question (written for this package) · Difficulty: Easy

144. Which pair correctly matches a harm act with the property it mainly affects?

A. Fabrication – Availability

B. Interception – Integrity

C. Interruption – Availability

D. Modification – Confidentiality

[OR] Original practice question (written for this package) · Difficulty: Medium

145. Sharing the password with a colleague is an example of ...

A. weak security administration

B. lack of user security awareness

C. a natural threat

D. a physical control

[OR] Original practice question (written for this package) · Difficulty: Medium

Chapter 2.1 — Authentication

Identification, authentication, factors and passwords

146. What is authentication?

A. Determining what a user is allowed to do
B. Verifying the identity of a user or entity
C. Encrypting a file
D. Recording system events only

[PB] Professor's MCQ bank (user-supplied file), original Q121 · Difficulty: Easy

147. What is identification?

A. Claiming an identity
B. Proving an identity
C. Assigning permissions
D. Encrypting a message

[PB] Professor's MCQ bank (user-supplied file), original Q122 · Difficulty: Easy

148. What is the difference between identification and authentication?

A. Identification claims identity; authentication verifies it
B. Identification grants all permissions; authentication deletes them
C. Both mean encryption
D. Both mean accounting

[PB] Professor's MCQ bank (user-supplied file), original Q123 · Difficulty: Easy

149. Which of the following is something a user knows?

A. Fingerprint
B. Smart card
C. Password
D. Face

[PB] Professor's MCQ bank (user-supplied file), original Q124 · Difficulty: Easy

150. Which of the following is something a user has?

A. Password
B. PIN memorized by the user
C. Smart card
D. Fingerprint

[PB] Professor's MCQ bank (user-supplied file), original Q125 · Difficulty: Easy

151. Which of the following is something a user is?

A. Password
B. Security token
C. Fingerprint
D. Smart card

[PB] Professor's MCQ bank (user-supplied file), original Q126 · Difficulty: Easy

152. Which is an example of biometric authentication?

A. Password
B. Fingerprint recognition
C. Security question
D. PIN

[PB] Professor's MCQ bank (user-supplied file), original Q127 · Difficulty: Easy

153. What is multifactor authentication (MFA)?

A. Using multiple accounts
B. Using two or more different authentication-factor categories
C. Using the same password twice
D. Using encryption without a key

[PB] Professor's MCQ bank (user-supplied file), original Q128 · Difficulty: Easy

154. Which combination is an example of multifactor authentication?

A. Password and PIN
B. Two passwords
C. Password and fingerprint
D. Two security questions

[PB] Professor's MCQ bank (user-supplied file), original Q129 · Difficulty: Medium

155. What is the purpose of a password salt?

A. To make passwords readable
B. To add random data to password processing so identical passwords need not have identical stored hashes
C. To replace authentication
D. To publish the password

[PB] Professor's MCQ bank (user-supplied file), original Q130 · Difficulty: Medium

156. Which practice improves password security?

A. Using short, predictable passwords
B. Reusing the same password everywhere
C. Using long, unique passwords
D. Writing passwords publicly

[PB] Professor's MCQ bank (user-supplied file), original Q131 · Difficulty: Easy

157. What is the purpose of account lockout after repeated failed logins?

A. To make encryption faster
B. To help limit repeated password-guessing attempts
C. To improve screen resolution
D. To eliminate authorization

[PB] Professor's MCQ bank (user-supplied file), original Q132 · Difficulty: Easy

158. What is a brute-force password attack?

A. Trying possible passwords until the correct one is found
B. Encrypting a file with AES
C. Assigning a role to a user
D. Creating a digital certificate

[PB] Professor's MCQ bank (user-supplied file), original Q133 · Difficulty: Easy

159. What is a dictionary attack?

A. Trying words and likely passwords from a list
B. Encrypting data with a public key
C. Removing access rights
D. Creating a hash from a random number only

[PB] Professor's MCQ bank (user-supplied file), original Q134 · Difficulty: Easy

160. Which question does identification answer?

A. What are you allowed to do?
B. Who are you claiming to be?
C. How large is the database?
D. Which memory area stores dynamic data?

[PB] Professor's MCQ bank (user-supplied file), original Q345 · Difficulty: Easy

161. Which question does authentication answer?

A. How can the claimed identity be verified?
B. Which operations are permitted?
C. How much memory is allocated?
D. Which program is running?

[PB] Professor's MCQ bank (user-supplied file), original Q346 · Difficulty: Easy

162. Which question does authorization answer?

A. Who are you?
B. How do you prove your identity?
C. What are you permitted to access or do?
D. What is the program counter?

[PB] Professor's MCQ bank (user-supplied file), original Q347 · Difficulty: Easy

163. Which is the correct order of the three identity and access-control concepts?

A. Authorization → Identification → Authentication.
B. Authentication → Authorization → Identification.
C. Identification → Authentication → Authorization.
D. Identification → Authorization → Authentication.

[PB] Professor's MCQ bank (user-supplied file), original Q361 · Difficulty: Easy

Previous-exam questions (2015–2019)

164. The passwords are suffer from some difficulties of use, these difficulties are .....

A. Revocation and use
B. Disclosure and lose
C. a & b
D. All previous false.

[PE] Previous exams 2016-17 & 2017-18 (Q1) · Difficulty: Easy

165. A credit cards with a magnetic stripe authentication mechanism is something .....

A. the user has
B. the user know
C. a & b
D. the user is

[PE] Previous exams 2016-17 & 2017-18 (Q2) · Difficulty: Easy

166. An authentication based on a biometrics are .....

A. biological properties
B. something you have
C. something you are
D. a & c

[PE] Previous exams 2016-17 & 2017-18 (Q3) · Difficulty: Easy

167. ..... is the act of asserting who a person is.

A. The password
B. Authentication
C. Identification
D. A physical key

[PE] Previous exams 2016-17 & 2017-18 (Q4) · Difficulty: Easy

168. ..... is the act of proving that the person is who she says she is.

A. The email address
B. Authentication
C. Identification
D. b & c

[PE] Previous exams 2016-17 & 2017-18 (Q5) · Difficulty: Easy

169. Fingerprints can be used for .....

A. What you have authentication
B. What you are authentication
C. What you know authentication
D. Biological authentication
E. b & d

[PE] Previous exams 2016-17 & 2017-18 (Q6) · Difficulty: Easy

170. Fingerprints can be used for .....

A. What you have authentication
B. What you are authentication
C. Biological identification
D. keeping things simple
E. All of the above

[PE] Previous exams 2015-16 & 2018-19 (Q1/Q1) · Difficulty: Medium

171. A passphrases can be used for .....

A. What you have authentication
B. What you are authentication
C. Biological identification
D. What you know authentication

[PE] Previous exams 2016-17 & 2017-18 (Q27) · Difficulty: Easy

172. The pattern of a person's voice can be used for .....

A. What you have authentication
B. What you are authentication
C. Biological identification
D. What you know authentication

[PE] Previous exams 2016-17 & 2017-18 (Q28) · Difficulty: Medium

173. An identity badges can be used for .....

A. What you have authentication
B. What you are authentication
C. Biological identification
D. What you know authentication

[PE] Previous exams 2016-17 & 2017-18 (Q29) · Difficulty: Easy

174. A bank card and a PIN combine two forms of authentication, ...

A. something the user has with something the user is.
B. something the user is with something the user knows.
C. something the user has with something the user knows.

[PE] Previous exams 2016-17 & 2017-18 (Q30) · Difficulty: Easy

175. What is strong authentication?

A. Strong authentication uses long passwords.
B. Strong authentication requires smart cards.
C. Strong authentication requires the use of at least two different authentication methods.
D. Strong authentication is provided via biometrics.
E. All of the above

[PE] Previous exams 2015-16 & 2018-19 (Q3/Q3) · Difficulty: Medium

176. What is the purpose of authentication?

A. To obtain proof of claimed identity
B. To allow use of different authorizations
C. To establish accountability
D. To implement access control
E. All of the above

[PE] Previous exams 2015-16 & 2018-19 (Q9/Q9) · Difficulty: Medium

Original practice questions

177. Which is “something you are”?

A. Smart card
B. Iris pattern
C. PIN
D. Passphrase

[OR] Original practice question (written for this package) · Difficulty: Easy

178. Which pair is two-factor authentication?

A. Password + PIN
B. Password + one-time code from a token
C. Two passwords
D. Fingerprint + fingerprint

[OR] Original practice question (written for this package) · Difficulty: Easy

179. Which statement about identification is correct?

A. It is secret and hard to guess
B. It is the act of asserting who a person is, and is usually public
C. It proves identity
D. It encrypts the password

[OR] Original practice question (written for this package) · Difficulty: Medium

180. In the 12-step password-guessing order, which comes first?

A. Complete English dictionary
B. No password at all
C. Brute force on the full character set
D. Name derived from the user's name

[OR] Original practice question (written for this package) · Difficulty: Medium

181. Why are brute-force attacks easier against short passwords?

A. There are only $26+26^2+26^3=18{,}278$ lowercase passwords of length ≤3
B. Short passwords are always dictionary words
C. Long passwords cannot be hashed
D. Salts do not work on short passwords

[OR] Original practice question (written for this package) · Difficulty: Medium

182. Which is NOT a good password criterion?

A. Mix of letters, digits and symbols
B. At least 12 characters
C. Your pet's name
D. Not reused across systems

[OR] Original practice question (written for this package) · Difficulty: Easy

183. Two users have identical stored password hashes. What can an attacker infer if no salt is used?

A. Nothing
B. They probably chose the same (maybe common) password
C. Both use biometrics
D. The hash is encrypted

[OR] Original practice question (written for this package) · Difficulty: Medium

184. A bank locks an account after five wrong PINs. This mainly counters ...

A. rainbow tables
B. online guessing
C. skimming
D. shoulder surfing of PIN

[OR] Original practice question (written for this package) · Difficulty: Medium

185. A biometric system rejects the real owner. This is a ...

A. false positive
B. false negative
C. salting error
D. replay

[OR] Original practice question (written for this package) · Difficulty: Medium

186. Which statement is TRUE about biometrics?

A. They are more reliable for identification than for authentication
B. Lowering false positives usually raises false negatives
C. They never change over time
D. Readers cannot be a single point of failure

[OR] Original practice question (written for this package) · Difficulty: Hard

187. An ID card that stays unchanged is a ... token.

A. dynamic
B. static
C. active only
D. remote

[OR] Original practice question (written for this package) · Difficulty: Easy

188. A token that generates a new one-time number every 30 seconds is ...

A. a passive token
B. a dynamic token
C. a static token
D. a biometric

[OR] Original practice question (written for this package) · Difficulty: Medium

189. What does skimming do?

A. Guesses passwords
B. Secretly copies authentication data from a token
C. Encrypts tokens
D. Revokes access

[OR] Original practice question (written for this package) · Difficulty: Medium

190. Single sign-on lets a user ...

A. log in once and access several systems
B. use no password ever
C. share a password
D. skip authorization

[OR] Original practice question (written for this package) · Difficulty: Easy

191. In a federated identity scheme, authentication is performed ...

A. separately in every system
B. in one place and trusted by the others
C. only by the user
D. by biometrics only

[OR] Original practice question (written for this package) · Difficulty: Medium

192. Adams may log in only 8:00–17:00 from the accounting office. Which idea is used?

A. Salt
B. Time and location as authentication context
C. Skimming
D. Rainbow table

[OR] Original practice question (written for this package) · Difficulty: Easy

193. Which of the following correctly orders the access-control building blocks?

A. Authorization, identification, authentication, accounting
B. Identification, authentication, authorization, accounting
C. Accounting, identification, authorization, authentication
D. Authentication, identification, accounting, authorization

[OR] Original practice question (written for this package) · Difficulty: Medium

194. Which is a disadvantage of passwords listed in the lecture?

A. Disclosure
B. Revocation
C. Loss
D. All of the above

[OR] Original practice question (written for this package) · Difficulty: Easy

195. A site shows “Your password is: ....” when you click “forgot password”. What does this suggest?

A. The password is stored in a recoverable form, not as a one-way hash
B. Good security practice
C. It uses salts
D. It uses MFA

[OR] Original practice question (written for this package) · Difficulty: Hard

Chapter 2.2 — Access Control

Access-control concepts, policies and logs

196. What does authorization determine?

A. Whether the user has proved their identity
B. What an authenticated user is allowed to access or do
C. Whether the computer has power
D. Whether a message is plaintext

[PB] Professor's MCQ bank (user-supplied file), original Q135 · Difficulty: Easy

197. What is access control?

A. A method for controlling access to resources according to permissions
B. A method for increasing processor speed
C. A method for encrypting every file
D. A method for deleting all accounts

[PB] Professor's MCQ bank (user-supplied file), original Q136 · Difficulty: Easy

198. What is a subject in access control?

A. A passive resource
B. An active entity requesting access
C. An encryption algorithm
D. A security label only

[PB] Professor's MCQ bank (user-supplied file), original Q137 · Difficulty: Easy

199. What is an object in access control?

A. An active entity requesting access
B. A passive resource that is accessed
C. A password only
D. A user authentication factor

[PB] Professor's MCQ bank (user-supplied file), original Q138 · Difficulty: Easy

200. Which is an example of a subject?

A. A file being read
B. A database table being accessed
C. A user process requesting access to a file
D. A document stored on disk

[PB] Professor's MCQ bank (user-supplied file), original Q139 · Difficulty: Easy

201. Which is an example of an object?

A. A process requesting access
B. A user requesting a file
C. A database table being accessed
D. An administrator requesting permission

[PB] Professor's MCQ bank (user-supplied file), original Q140 · Difficulty: Easy

202. What are the four building blocks of access control described in the chapter?

A. Identification, Authentication, Authorization, Accounting
B. Encryption, Decryption, Hashing, Signing
C. Confidentiality, Integrity, Availability, Privacy
D. Password, PIN, Fingerprint, Smart Card

[PB] Professor's MCQ bank (user-supplied file), original Q141 · Difficulty: Easy

203. What is the purpose of accounting in access control?

A. To record or track activities and access events
B. To encrypt all files
C. To prove a fingerprint
D. To create a public key

[PB] Professor's MCQ bank (user-supplied file), original Q142 · Difficulty: Easy

204. Which category of controls enforces security rules through policies?

A. Physical
B. Administrative
C. Logical only
D. Environmental

[PB] Professor's MCQ bank (user-supplied file), original Q143 · Difficulty: Easy

205. Which controls implement restrictions on access to objects using technical mechanisms?

A. Logical controls
B. Administrative controls only
C. Physical controls only
D. Natural controls

[PB] Professor's MCQ bank (user-supplied file), original Q144 · Difficulty: Easy

206. Which controls limit physical access to hardware?

A. Logical
B. Administrative
C. Physical
D. Cryptographic

[PB] Professor's MCQ bank (user-supplied file), original Q145 · Difficulty: Easy

207. What is asset or data classification?

A. Classifying data according to the risk associated with its compromise
B. Deleting all old data
C. Creating a password for every file
D. Converting data to ciphertext

[PB] Professor's MCQ bank (user-supplied file), original Q146 · Difficulty: Easy

208. What is asset marking?

A. Removing the classification
B. Labeling an asset so its classification is clear
C. Encrypting every object
D. Creating a new user role

[PB] Professor's MCQ bank (user-supplied file), original Q147 · Difficulty: Easy

209. What is access policy definition?

A. Defining rules that govern access to assets
B. Deleting all access logs
C. Generating an RSA key only
D. Changing plaintext into ciphertext

[PB] Professor's MCQ bank (user-supplied file), original Q148 · Difficulty: Easy

210. What is data disposal?

A. Assigning a role
B. Properly eliminating or disposing of data or assets
C. Authenticating a user
D. Creating a digital signature

[PB] Professor's MCQ bank (user-supplied file), original Q149 · Difficulty: Easy

211. Which access-control decision determines whether a subject can read or write an object?

A. Access authorization
B. Steganography
C. Cryptanalysis
D. Hashing

[PB] Professor's MCQ bank (user-supplied file), original Q150 · Difficulty: Easy

212. What does access-control granularity mean?

A. The size of a computer screen
B. The fineness or specificity of access control
C. The speed of encryption
D. The number of processors

[PB] Professor's MCQ bank (user-supplied file), original Q151 · Difficulty: Easy

213. Which permission allows a subject to view a file without necessarily changing it?

A. Write
B. Read
C. Delete
D. Administer

[PB] Professor's MCQ bank (user-supplied file), original Q152 · Difficulty: Easy

214. Which permission allows a subject to modify a file?

A. Read
B. Write
C. Identify
D. Authenticate

[PB] Professor's MCQ bank (user-supplied file), original Q153 · Difficulty: Easy

215. Why must access policies sometimes be revisited?

A. To determine whether the policy is working as intended
B. To ensure that all users have administrator privileges
C. To remove all security controls
D. To eliminate authentication

[PB] Professor's MCQ bank (user-supplied file), original Q154 · Difficulty: Easy

216. What is the purpose of tracking access activity?

A. To help monitor and evaluate access-policy effectiveness
B. To convert all files into plaintext
C. To eliminate the need for authorization
D. To replace the operating system

[PB] Professor's MCQ bank (user-supplied file), original Q155 · Difficulty: Easy

Access-control models (DAC, MAC, RBAC, ABAC, formal models)

217. What does DAC stand for?

A. Data Access Configuration
B. Discretionary Access Control
C. Direct Authentication Control
D. Digital Access Cryptography

[PB] Professor's MCQ bank (user-supplied file), original Q156 · Difficulty: Easy

218. In DAC, who commonly determines permissions for an object?

A. The object owner
B. Every user on the network
C. The encryption algorithm
D. The certificate issuer only

[PB] Professor's MCQ bank (user-supplied file), original Q157 · Difficulty: Easy

219. What does MAC stand for?

A. Mandatory Access Control
B. Managed Authentication Cryptography
C. Multiple Access Cipher
D. Manual Account Configuration

[PB] Professor's MCQ bank (user-supplied file), original Q158 · Difficulty: Easy

220. Which model enforces access according to centrally defined security policies and labels?

A. DAC
B. MAC
C. RBAC
D. ABAC

[PB] Professor's MCQ bank (user-supplied file), original Q159 · Difficulty: Easy

221. Which access-control model assigns permissions based on organizational roles?

A. DAC
B. MAC
C. RBAC
D. Steganography

[PB] Professor's MCQ bank (user-supplied file), original Q160 · Difficulty: Easy

222. What does RBAC stand for?

A. Role-Based Access Control
B. Rule-Based Authentication Cipher
C. Read-Based Access Configuration
D. Restricted Binary Access Code

[PB] Professor's MCQ bank (user-supplied file), original Q161 · Difficulty: Easy

223. In RBAC, permissions are primarily associated with what?

A. Roles
B. Random numbers
C. Encryption keys
D. Network addresses only

[PB] Professor's MCQ bank (user-supplied file), original Q162 · Difficulty: Easy

224. Why is RBAC useful in an organization with high employee turnover?

A. Permissions can be managed through roles rather than individually for every user
B. Every employee must receive administrator privileges
C. It eliminates authentication
D. It does not require security policies

[PB] Professor's MCQ bank (user-supplied file), original Q163 · Difficulty: Medium

225. What does ABAC stand for?

A. Attribute-Based Access Control

B. Authentication-Based Account Control

C. Automated Binary Access Code

D. Authorized Block Algorithm Cipher

[PB] Professor's MCQ bank (user-supplied file), original Q164 · Difficulty: Easy

226. Which model can make access decisions based on attributes of the subject, object, and environment?

A. DAC only

B. ABAC

C. Rail Fence

D. DES

[PB] Professor's MCQ bank (user-supplied file), original Q165 · Difficulty: Easy

227. A file owner grants another user permission to read the file. Which model best fits this situation?

A. DAC

B. MAC

C. DES

D. AES

[PB] Professor's MCQ bank (user-supplied file), original Q166 · Difficulty: Easy

228. A government system restricts access according to security classifications and centrally enforced rules. Which model best fits?

A. DAC

B. MAC

C. RBAC only

D. Rail Fence

[PB] Professor's MCQ bank (user-supplied file), original Q167 · Difficulty: Easy

229. A company gives employees permissions according to roles such as Accountant and Manager. Which model is being used?

A. RBAC

B. Steganography

C. Hill cipher

D. Hashing

[PB] Professor's MCQ bank (user-supplied file), original Q168 · Difficulty: Easy

230. A system allows access only when the user's department, the data classification, and the current time satisfy a policy. Which model is most suitable?

A. ABAC

B. Caesar cipher

C. DES

D. One-Time Pad

[PB] Professor's MCQ bank (user-supplied file), original Q169 · Difficulty: Medium

231. Which access-control model is associated with preventing conflicts of interest?

A. Brewer and Nash

B. AES

C. RSA

D. Caesar

[PB] Professor's MCQ bank (user-supplied file), original Q170 · Difficulty: Medium

232. Which model is primarily focused on confidentiality?

A. Bell–LaPadula

B. Biba

C. DES

D. Hill

[PB] Professor's MCQ bank (user-supplied file), original Q171 · Difficulty: Medium

233. Which model is primarily focused on integrity?

A. Bell–LaPadula

B. Biba

C. Rail Fence

D. Vigenère

[PB] Professor's MCQ bank (user-supplied file), original Q172 · Difficulty: Medium

234. Which model focuses on data integrity and well-formed transactions?

A. Clark–Wilson

B. Bell–LaPadula only

C. RSA

D. AES

[PB] Professor's MCQ bank (user-supplied file), original Q173 · Difficulty: Medium

235. Which models are associated with formal analysis of access-control policies and system safety?

A. Harrison–Ruzzo–Ullman

B. Caesar and Playfair

C. AES and DES

D. RSA and Diffie–Hellman

[PB] Professor's MCQ bank (user-supplied file), original Q174 · Difficulty: Medium

236. Which model is associated with secure creation, deletion, and access control of subjects and objects?

A. Graham–Denning

B. Vigenère

C. AES

D. One-Time Pad

[PB] Professor's MCQ bank (user-supplied file), original Q175 · Difficulty: Medium

Previous-exam questions (2015–2019)

237. In the ....., the object list shows all subjects who should have access to the object & what their access is.

A. access control list

B. directory

C. access control matrix

D. capability

[PE] Previous exams 2015-16 & 2018-19 (Q24/Q23) · Difficulty: Easy

238. A ..... is an unforgeable token that gives the possessor certain rights to an object.

A. Role-Based Access Control

B. Capability

C. Procedure-Oriented Access Control

D. all true

[PE] Previous exams 2015-16 & 2018-19 (Q25/Q24) · Difficulty: Easy

239. In the access control list, ...

A. a directory is created for each subject.

B. a directory is created for each object.

C. there is one access control list per object.

D. All false

[PE] Previous exams 2015-16 & 2018-19 (Q29/Q25) · Difficulty: Easy

240. In the directory, a list is created for .....

A. each subject

B. each object

C. one access control list per object

D. different access control lists per subject.

[PE] Previous exams 2015-16 & 2018-19 (Q30/Q26) · Difficulty: Easy

241. A capability can be created only by a specific request from a user to the .....

A. key distribution center
B. operating system
C. Kerberos
D. a & b

[PE] Previous exams 2015-16 & 2018-19 (Q31/Q27) · Difficulty: Easy

242. The access control matrix is sparse, because most subjects .....

A. do have access rights to most objects.
B. do have access rights to key distribution center.
C. do not have access rights to most objects.
D. do have access rights to key distribution center.

[PE] Previous exams 2015-16 & 2018-19 (Q32/Q28) · Difficulty: Easy

243. In ....., not allowing access to unnecessary objects guards against security weaknesses if a part of the protection mechanism should fail.

A. verify acceptable usage
B. check every access
C. enforce least privilege
D. non all previous.

[PE] Previous exams 2015-16 & 2018-19 (Q33/Q29) · Difficulty: Easy

244. In ....., we may want not only to control who or what has access to object but also to be assured that the accesses performed are legitimate object accesses.

A. verify acceptable usage
B. check every access
C. enforce least privilege
D. non all previous.

[PE] Previous exams 2015-16 & 2018-19 (Q34/Q30) · Difficulty: Easy

245. In the ....., allowing pseudonyms leads to multiple permissions that are not necessarily consistent.

A. access control list
B. directory
C. access control matrix
D. capability

[PE] Previous exams 2015-16 & 2018-19 (Q35) · Difficulty: Medium

Original practice questions

246. In access control, which is a typical object?

A. A user process
B. A file
C. An administrator
D. A login session

[OR] Original practice question (written for this package) · Difficulty: Easy

247. Which list shows, for ONE object, all subjects that may access it?

A. Directory
B. ACL
C. Capability list
D. Privilege list

[OR] Original practice question (written for this package) · Difficulty: Medium

248. Revoking all access to one file is easiest with ...

A. an access control list
B. a directory per user
C. capabilities held by users
D. passwords

[OR] Original practice question (written for this package) · Difficulty: Medium

249. Removing a user’s rights everywhere is easiest with ...

A. a privilege list (row of the matrix)
B. one ACL per object
C. a rainbow table
D. a salt

[OR] Original practice question (written for this package) · Difficulty: Medium

250. Unix permissions (u,g,w) are a form of ...

A. capability
B. ACL with user–group–world
C. directory only
D. RBAC only

[OR] Original practice question (written for this package) · Difficulty: Medium

251. Which model best fits a military system with labels like Secret and Top Secret?

A. DAC
B. MAC
C. RBAC
D. ABAC

[OR] Original practice question (written for this package) · Difficulty: Medium

252. In DAC, which is commonly used to enforce owner decisions?

A. Security labels

B. ACLs

C. Biometrics

D. Salts

[OR] Original practice question (written for this package) · Difficulty: Medium

253. A hospital allows a nurse to read records only if she works in the same ward, during her shift. Which model?

A. DAC

B. MAC

C. RBAC only

D. ABAC

[OR] Original practice question (written for this package) · Difficulty: Hard

254. The reference monitor property “always invoked” means ...

A. it checks every access attempt

B. it runs once a day

C. it can be disabled

D. it is large and complex

[OR] Original practice question (written for this package) · Difficulty: Medium

255. Giving a program only the access it needs is the principle of ...

A. least privilege

B. granularity

C. accounting

D. salting

[OR] Original practice question (written for this package) · Difficulty: Easy

256. A finer granularity of access control usually ...

A. reduces the number of decisions

B. increases the number of decisions and the performance penalty

C. has no cost

D. removes the need for policy

[OR] Original practice question (written for this package) · Difficulty: Medium

257. Which is the main purpose of an access log?

A. Speeding up the CPU

B. After-the-fact analysis of who accessed what

C. Encrypting files

D. Replacing authentication

[OR] Original practice question (written for this package) · Difficulty: Medium

258. A capability held by Alice is encrypted under a key known only to the OS and contains Alice's identity. Why?

A. So Alice cannot copy it and give it to Bob

B. To make it faster

C. To let anyone forge it

D. To hide the object

[OR] Original practice question (written for this package) · Difficulty: Hard

259. Procedure-oriented access control implements the principle of ...

A. information hiding

B. brute force

C. replay

D. skimming

[OR] Original practice question (written for this package) · Difficulty: Medium

Chapter 2.3 — Cryptography

Cryptography basics and terminology

260. What is cryptography?

A. A method of deleting information

B. The study and use of techniques to protect information through transformation

C. A method of controlling physical access only

D. A database management technique

[PB] Professor's MCQ bank (user-supplied file), original Q105 · Difficulty: Easy

261. What is the primary purpose of encryption?

A. To make information easier to read

B. To conceal the meaning of information from unauthorized parties

C. To increase the size of a database

D. To delete sensitive information

[PB] Professor's MCQ bank (user-supplied file), original Q106 · Difficulty: Easy

262. What is plaintext?

A. The encrypted message

B. The encryption key

C. The original, readable message

D. The digital signature

[PB] Professor's MCQ bank (user-supplied file), original Q107 · Difficulty: Easy

263. What is ciphertext?

A. The original message

B. The encrypted message

C. The secret key only

D. The public key only

[PB] Professor's MCQ bank (user-supplied file), original Q108 · Difficulty: Easy

264. What is encryption?

A. Converting ciphertext into plaintext

B. Converting plaintext into ciphertext

C. Deleting a secret key

D. Verifying a user's identity

[PB] Professor's MCQ bank (user-supplied file), original Q109 · Difficulty: Easy

265. What is decryption?

A. Converting plaintext into ciphertext
B. Restoring plaintext from ciphertext
C. Creating a user account
D. Calculating access permissions

[PB] Professor's MCQ bank (user-supplied file), original Q110 · Difficulty: Easy

266. What is a cryptosystem?

A. A system that performs encryption and decryption
B. A system used only to create user accounts
C. A physical security device
D. A network cable

[PB] Professor's MCQ bank (user-supplied file), original Q111 · Difficulty: Easy

267. What is cryptanalysis?

A. Creating passwords
B. Studying techniques for breaking or analyzing encrypted messages
C. Managing database records
D. Creating physical access cards

[PB] Professor's MCQ bank (user-supplied file), original Q112 · Difficulty: Easy

268. What is cryptology?

A. Cryptography only
B. Cryptanalysis only
C. Both cryptography and cryptanalysis
D. Authentication only

[PB] Professor's MCQ bank (user-supplied file), original Q113 · Difficulty: Easy

269. Who is a cryptographer?

A. A person who works with cryptographic methods to protect information
B. A person who manages physical buildings only
C. A person who creates network cables
D. A person who only manages user accounts

[PB] Professor's MCQ bank (user-supplied file), original Q114 · Difficulty: Easy

270. Who is a cryptanalyst?

A. A person who attempts to analyze or break encrypted messages
B. A person who only installs operating systems
C. A person who creates database tables
D. A person who manages employee attendance

[PB] Professor's MCQ bank (user-supplied file), original Q115 · Difficulty: Easy

271. What is steganography?

A. Hiding the existence of a message or data
B. Encrypting every message with RSA
C. Managing user roles
D. Calculating a hash only

[PB] Professor's MCQ bank (user-supplied file), original Q116 · Difficulty: Easy

272. What is the main difference between cryptography and steganography?

A. They are exactly the same
B. Cryptography hides the meaning; steganography hides the existence of the message
C. Cryptography hides the existence; steganography always encrypts the message
D. Neither can protect information

[PB] Professor's MCQ bank (user-supplied file), original Q117 · Difficulty: Medium

Classical ciphers

273. Which are two common types of operations used in classical encryption?

A. Substitution and transposition
B. Authentication and accounting
C. Identification and authorization
D. Reading and writing

[PB] Professor's MCQ bank (user-supplied file), original Q176 · Difficulty: Easy

274. What is a substitution cipher?

A. A cipher that replaces symbols with other symbols
B. A cipher that only deletes letters
C. A cipher that assigns user roles
D. A cipher that creates digital certificates

[PB] Professor's MCQ bank (user-supplied file), original Q177 · Difficulty: Easy

275. What is a transposition cipher?

A. A cipher that rearranges the positions of symbols
B. A cipher that always replaces each letter with a number
C. A method of biometric authentication
D. A public-key certificate

[PB] Professor's MCQ bank (user-supplied file), original Q178 · Difficulty: Easy

276. Which of the following is a classical substitution cipher?

A. Caesar cipher
B. AES
C. RSA
D. Diffie–Hellman

[PB] Professor's MCQ bank (user-supplied file), original Q179 · Difficulty: Easy

277. Which cipher uses a keyword to control a series of letter substitutions?

A. Vigenère cipher
B. DES
C. RSA
D. Diffie–Hellman

[PB] Professor's MCQ bank (user-supplied file), original Q180 · Difficulty: Medium

278. Which classical cipher uses a pair of letters and a 5×5 letter matrix?

A. Playfair cipher
B. Caesar cipher
C. RSA
D. AES

[PB] Professor's MCQ bank (user-supplied file), original Q181 · Difficulty: Medium

279. Which classical cipher uses matrix operations?

A. Hill cipher
B. Rail Fence cipher
C. Caesar cipher
D. DES

[PB] Professor's MCQ bank (user-supplied file), original Q182 · Difficulty: Medium

280. Which cipher is a transposition cipher that arranges letters in a zigzag pattern?

A. Rail Fence cipher
B. RSA
C. AES
D. Vigenère

[PB] Professor's MCQ bank (user-supplied file), original Q183 · Difficulty: Medium

281. What is a One-Time Pad?

A. A cipher using a truly random key as long as the message, used only once and kept secret
B. A password reused for every file
C. A public-key certificate
D. A role-based access model

[PB] Professor's MCQ bank (user-supplied file), original Q184 · Difficulty: Medium

282. Under what conditions can a One-Time Pad provide perfect secrecy?

A. The key is random, as long as the message, secret, and never reused
B. The key is short and reused many times
C. The key is publicly available
D. No key is required

[PB] Professor's MCQ bank (user-supplied file), original Q185 · Difficulty: Medium

283. What is a cryptographic key?

A. Information used by a cryptographic algorithm to control a transformation

B. A user account name

C. A file extension

D. A physical access door

[PB] Professor's MCQ bank (user-supplied file), original Q186 · Difficulty: Easy

Symmetric/asymmetric, stream/block, DES

284. What are the two main categories of modern encryption?

A. Symmetric and asymmetric encryption

B. Physical and administrative encryption

C. Identification and accounting

D. Read and write encryption

[PB] Professor's MCQ bank (user-supplied file), original Q187 · Difficulty: Easy

285. What is symmetric encryption?

A. Encryption and decryption use the same shared secret key

B. Encryption uses no key

C. Encryption uses a public/private key pair only

D. Every user has a different hash function

[PB] Professor's MCQ bank (user-supplied file), original Q188 · Difficulty: Easy

286. What is a major requirement for secure symmetric encryption?

A. A strong algorithm and secure key distribution and storage

B. Publishing the secret key

C. Reusing a weak password

D. Avoiding decryption

[PB] Professor's MCQ bank (user-supplied file), original Q189 · Difficulty: Medium

287. What is asymmetric encryption?

A. A system that uses a related public/private key pair

B. A system that uses no keys

C. A system that always uses only one shared secret key

D. A system that only rearranges letters

[PB] Professor's MCQ bank (user-supplied file), original Q190 · Difficulty: Easy

288. Which key is normally shared publicly in a public-key cryptosystem?

A. Private key

B. Public key

C. Session secret only

D. Password hash salt only

[PB] Professor's MCQ bank (user-supplied file), original Q191 · Difficulty: Easy

289. Which key must be kept secret by its owner?

A. Public key
B. Private key
C. Public certificate
D. Public identity

[PB] Professor's MCQ bank (user-supplied file), original Q192 · Difficulty: Easy

290. Which algorithm is a symmetric block cipher?

A. AES
B. RSA
C. Diffie–Hellman
D. Digital certificates

[PB] Professor's MCQ bank (user-supplied file), original Q193 · Difficulty: Easy

291. Which pair consists of symmetric block ciphers?

A. AES and DES
B. RSA and Diffie–Hellman
C. RSA and AES
D. Diffie–Hellman and DES

[PB] Professor's MCQ bank (user-supplied file), original Q194 · Difficulty: Easy

292. Which algorithm is an asymmetric public-key algorithm?

A. RSA
B. AES
C. DES
D. Rail Fence

[PB] Professor's MCQ bank (user-supplied file), original Q195 · Difficulty: Easy

293. What is a block cipher?

A. A cipher that processes data in fixed-size blocks
B. A cipher that processes only usernames
C. A cipher that has no key
D. A cipher that only rearranges roles

[PB] Professor's MCQ bank (user-supplied file), original Q196 · Difficulty: Easy

294. What is a stream cipher?

A. A cipher that processes data as a stream of symbols or units
B. A cipher that only processes fixed 128-bit blocks
C. A model of access control
D. A certificate authority

[PB] Professor's MCQ bank (user-supplied file), original Q197 · Difficulty: Easy

295. Which issue can arise when using a block cipher with data that does not fill a complete block?

A. Padding may be required, depending on the mode

B. The private key becomes public

C. Authentication becomes unnecessary

D. All plaintext is automatically deleted

[PB] Professor's MCQ bank (user-supplied file), original Q198 · Difficulty: Medium

296. What is DES?

A. A symmetric block cipher

B. An asymmetric key-exchange protocol

C. An access-control model

D. A hashing-only algorithm

[PB] Professor's MCQ bank (user-supplied file), original Q199 · Difficulty: Easy

297. What is the effective key length of standard DES?

A. 32 bits

B. 56 bits

C. 128 bits

D. 256 bits

[PB] Professor's MCQ bank (user-supplied file), original Q200 · Difficulty: Easy

298. What is the block size of DES?

A. 32 bits

B. 56 bits

C. 64 bits

D. 128 bits

[PB] Professor's MCQ bank (user-supplied file), original Q201 · Difficulty: Easy

299. How many rounds does DES use?

A. 8

B. 10

C. 16

D. 32

[PB] Professor's MCQ bank (user-supplied file), original Q202 · Difficulty: Easy

300. Why is DES considered insecure for modern protection?

A. Its effective key is too short to resist modern brute-force capabilities

B. It does not use a key

C. It is a biometric system

D. It uses a 4096-bit key

[PB] Professor's MCQ bank (user-supplied file), original Q203 · Difficulty: Medium

AES, confusion and diffusion

301. What is AES?

A. Advanced Encryption Standard

B. Automatic Entry System

C. Asymmetric Encryption Service

D. Authorized Encryption Security

[PB] Professor's MCQ bank (user-supplied file), original Q204 · Difficulty: Easy

302. What is the block size of AES?

A. 56 bits

B. 64 bits

C. 128 bits

D. 256 bits

[PB] Professor's MCQ bank (user-supplied file), original Q205 · Difficulty: Easy

303. Which key lengths does AES support?

A. 56, 64, 80 bits

B. 128, 192, 256 bits

C. 32, 64, 96 bits

D. 512 and 1024 bits only

[PB] Professor's MCQ bank (user-supplied file), original Q206 · Difficulty: Easy

304. How many rounds does AES-128 use?

A. 8

B. 10

C. 12

D. 14

[PB] Professor's MCQ bank (user-supplied file), original Q207 · Difficulty: Easy

305. How many rounds does AES-192 use?

A. 10

B. 12

C. 14

D. 16

[PB] Professor's MCQ bank (user-supplied file), original Q208 · Difficulty: Easy

306. How many rounds does AES-256 use?

A. 10

B. 12

C. 14

D. 16

[PB] Professor's MCQ bank (user-supplied file), original Q209 · Difficulty: Easy

307. Which of the following is an AES transformation?

A. ShiftRows
B. Account Lockout
C. User Identification
D. Role Assignment

[PB] Professor's MCQ bank (user-supplied file), original Q210 · Difficulty: Easy

308. Which AES transformation substitutes each byte using a substitution table?

A. SubBytes
B. ShiftRows
C. MixColumns
D. AddRoundKey

[PB] Professor's MCQ bank (user-supplied file), original Q211 · Difficulty: Easy

309. Which AES transformation shifts the rows of the state?

A. SubBytes
B. ShiftRows
C. MixColumns
D. AddRoundKey

[PB] Professor's MCQ bank (user-supplied file), original Q212 · Difficulty: Easy

310. Which AES transformation mixes data within each column?

A. MixColumns
B. ShiftRows
C. Authentication
D. Accounting

[PB] Professor's MCQ bank (user-supplied file), original Q213 · Difficulty: Easy

311. Which AES transformation combines the state with a round key?

A. AddRoundKey
B. SubBytes
C. ShiftRows
D. MixColumns

[PB] Professor's MCQ bank (user-supplied file), original Q214 · Difficulty: Easy

312. What does confusion aim to do in cryptography?

A. Make the relationship between the key and ciphertext difficult to analyze
B. Publish the key
C. Remove authentication
D. Make plaintext readable to everyone

[PB] Professor's MCQ bank (user-supplied file), original Q215 · Difficulty: Medium

313. What does diffusion aim to do?

A. Spread the influence of plaintext bits across ciphertext bits

B. Reveal the secret key

C. Delete the ciphertext

D. Assign user roles

[PB] Professor's MCQ bank (user-supplied file), original Q216 · Difficulty: Medium

RSA

314. What is RSA?

A. A public-key cryptographic algorithm

B. A physical access-control mechanism

C. A classical transposition cipher

D. A biometric authentication factor

[PB] Professor's MCQ bank (user-supplied file), original Q217 · Difficulty: Easy

315. RSA key generation commonly begins by choosing what?

A. Two prime numbers

B. Two usernames

C. Two passwords only

D. Two hash outputs

[PB] Professor's MCQ bank (user-supplied file), original Q218 · Difficulty: Easy

316. In RSA, if the selected primes are p and q, what is n?

A. p + q

B. q

C. p × q

D. p / q

[PB] Professor's MCQ bank (user-supplied file), original Q219 · Difficulty: Easy

317. If p = 17 and q = 11, what is n?

A. 28

B. 187

C. 160

D. 23

[PB] Professor's MCQ bank (user-supplied file), original Q220 · Difficulty: Easy

318. If p = 17 and q = 11, what is φ(n) in the standard RSA calculation?

A. 187

B. 160

C. 28

D. 17

[PB] Professor's MCQ bank (user-supplied file), original Q221 · Difficulty: Easy

319. In the chapter's RSA example, which value is used as the public exponent e?

A. 11
B. 17
C. 7
D. 23

[PB] Professor's MCQ bank (user-supplied file), original Q222 · Difficulty: Easy

320. In the chapter's RSA example, what is the private exponent d?

A. 7
B. 11
C. 17
D. 23

[PB] Professor's MCQ bank (user-supplied file), original Q223 · Difficulty: Medium

321. In the example with p = 17, q = 11, and e = 7, what is the public key?

A. (23, 187)
B. (7, 187)
C. (17, 11)
D. (160, 187)

[PB] Professor's MCQ bank (user-supplied file), original Q224 · Difficulty: Easy

322. In the same example, what is the private key?

A. (7, 187)
B. (17, 11)
C. (23, 187)
D. (160, 23)

[PB] Professor's MCQ bank (user-supplied file), original Q225 · Difficulty: Easy

323. In the chapter's RSA example, if M = 88, what ciphertext C is obtained?

A. 88
B. 11
C. 187
D. 23

[PB] Professor's MCQ bank (user-supplied file), original Q226 · Difficulty: Medium

324. What happens when the RSA ciphertext is correctly decrypted using the corresponding private key?

A. The original plaintext is recovered
B. The ciphertext becomes the public key
C. The modulus becomes zero
D. The message is permanently deleted

[PB] Professor's MCQ bank (user-supplied file), original Q227 · Difficulty: Easy

325. Which key is normally used to encrypt data for a recipient in a basic public-key encryption scheme?

A. The recipient's public key

B. The recipient's private key

C. The sender's password

D. A public hash value

[PB] Professor's MCQ bank (user-supplied file), original Q228 · Difficulty: Medium

326. Which key is used to decrypt data encrypted for a recipient using that recipient's public key?

A. The recipient's private key

B. The recipient's public key

C. Any user's public key

D. A digital certificate only

[PB] Professor's MCQ bank (user-supplied file), original Q229 · Difficulty: Easy

Hashes, digital signatures, certificates, key exchange

327. What is a cryptographic hash function?

A. A function that maps input data to a fixed-size digest

B. A function that always decrypts ciphertext

C. A method of assigning employee roles

D. A method of physical authentication

[PB] Professor's MCQ bank (user-supplied file), original Q230 · Difficulty: Easy

328. What is a hash value?

A. A fixed-size output produced by a hash function

B. The private key itself

C. The original password in readable form

D. A user role

[PB] Professor's MCQ bank (user-supplied file), original Q231 · Difficulty: Easy

329. What is a common use of cryptographic hashing?

A. Detecting changes in data

B. Physically locking a server room

C. Assigning a role to every employee

D. Increasing the size of a public key

[PB] Professor's MCQ bank (user-supplied file), original Q232 · Difficulty: Easy

330. Which statement best describes a cryptographic hash function?

A. It is generally designed to be one-way, not to recover the original input

B. It must always be reversible with a private key

C. It is the same as AES encryption

D. It is always a digital certificate

[PB] Professor's MCQ bank (user-supplied file), original Q233 · Difficulty: Medium

331. What is the digest length of MD5?

A. 64 bits
B. 128 bits
C. 160 bits
D. 256 bits

[PB] Professor's MCQ bank (user-supplied file), original Q234 · Difficulty: Easy

332. Which statement about MD5 is correct?

A. It is recommended for modern collision-resistant digital signatures
B. It produces a 128-bit digest but is no longer considered secure against collision attacks
C. It is a public-key encryption algorithm
D. It is an access-control model

[PB] Professor's MCQ bank (user-supplied file), original Q235 · Difficulty: Medium

333. In the chapter's historical discussion, what digest length is associated with the SHA/SHS version presented there?

A. 56 bits
B. 64 bits
C. 128 bits
D. 160 bits

[PB] Professor's MCQ bank (user-supplied file), original Q236 · Difficulty: Easy

334. What is a digital signature primarily used to provide?

A. Authenticity, integrity, and support for non-repudiation
B. Confidentiality in every case by itself
C. Physical security
D. Password storage only

[PB] Professor's MCQ bank (user-supplied file), original Q237 · Difficulty: Medium

335. Which key does the signer use to create a conventional public-key digital signature?

A. The signer's private key
B. The signer's public key
C. The recipient's password
D. A public certificate only

[PB] Professor's MCQ bank (user-supplied file), original Q238 · Difficulty: Medium

336. Which key is normally used to verify a digital signature?

A. The signer's public key
B. The signer's private key
C. The recipient's private key
D. A shared password only

[PB] Professor's MCQ bank (user-supplied file), original Q239 · Difficulty: Medium

337. Does a digital signature, by itself, necessarily provide message confidentiality?

A. Yes, always
B. No
C. Only if the message is long
D. Only if the hash is 128 bits

[PB] Professor's MCQ bank (user-supplied file), original Q240 · Difficulty: Medium

338. What is a digital certificate used for?

A. Binding an identity to a public key
B. Replacing all private keys
C. Encrypting every file automatically
D. Removing the need for verification

[PB] Professor's MCQ bank (user-supplied file), original Q241 · Difficulty: Easy

339. What is the role of a Certificate Authority (CA)?

A. Issuing or signing certificates according to its certificate process
B. Recovering every user's private key
C. Replacing the operating system
D. Assigning physical access cards only

[PB] Professor's MCQ bank (user-supplied file), original Q242 · Difficulty: Easy

340. What is a common purpose of a hash in a digital-signature process?

A. To create a digest of the message that can be signed and verified
B. To replace the public key with a password
C. To hide the existence of the message
D. To provide physical access

[PB] Professor's MCQ bank (user-supplied file), original Q243 · Difficulty: Medium

341. What is the purpose of key exchange?

A. To establish or share keying material between parties
B. To delete all public keys
C. To change plaintext into a hash only
D. To create user roles

[PB] Professor's MCQ bank (user-supplied file), original Q244 · Difficulty: Easy

342. What is Diffie–Hellman primarily used for?

A. Establishing a shared secret over a communication channel
B. Encrypting data using AES rounds
C. Managing user roles
D. Creating fingerprints

[PB] Professor's MCQ bank (user-supplied file), original Q245 · Difficulty: Easy

343. Does basic Diffie–Hellman, by itself, authenticate the identity of the other party?

A. Yes, always

B. No

C. Only when the key is 128 bits

D. Only when the user has a password

[PB] Professor's MCQ bank (user-supplied file), original Q246 · Difficulty: Medium

Counting keys

344. What is a major challenge in symmetric-key cryptography?

A. Securely distributing and protecting the shared secret key

B. The absence of a secret key

C. The requirement to publish every key

D. The inability to encrypt data

[PB] Professor's MCQ bank (user-supplied file), original Q247 · Difficulty: Easy

345. For n users who each need a distinct symmetric key with every other user, how many pairwise keys are required?

A. n

B. n^2

C. n(n - 1) / 2

D. 2n

[PB] Professor's MCQ bank (user-supplied file), original Q248 · Difficulty: Medium

346. In a basic public-key system, how many keys are associated with each user?

A. One public/private pair, or two keys

B. One key for the entire world

C. No keys

D. Four private keys only

[PB] Professor's MCQ bank (user-supplied file), original Q249 · Difficulty: Easy

347. For n users, if each user has one public/private key pair, how many individual public and private keys are there altogether?

A. n

B. 2n

C. n(n - 1)

D. n(n - 1) / 2

[PB] Professor's MCQ bank (user-supplied file), original Q250 · Difficulty: Medium

Cryptography/security tools

348. Which tool is commonly used for cryptographic operations and certificate management?

A. OpenSSL
B. Microsoft Paint
C. Calculator only
D. Notepad only

[PB] Professor's MCQ bank (user-supplied file), original Q251 · Difficulty: Easy

349. Which tools are associated with password-hash auditing and password recovery testing?

A. Hashcat and John the Ripper
B. AES and RSA
C. RBAC and ABAC
D. Playfair and Rail Fence

[PB] Professor's MCQ bank (user-supplied file), original Q252 · Difficulty: Easy

350. Which tools are associated with learning, exploring, or experimenting with cryptography?

A. CrypTool and CyberChef
B. RBAC and MAC
C. Bell–LaPadula and Biba
D. Smart cards and fingerprints

[PB] Professor's MCQ bank (user-supplied file), original Q253 · Difficulty: Easy

351. Which tool is commonly used for network-protocol analysis?

A. Wireshark
B. Hill cipher
C. AES
D. Graham–Denning

[PB] Professor's MCQ bank (user-supplied file), original Q254 · Difficulty: Easy

352. Which tool is associated with wireless-network security auditing?

A. Aircrack-ng
B. Clark–Wilson
C. Bell–LaPadula
D. MD5

[PB] Professor's MCQ bank (user-supplied file), original Q255 · Difficulty: Easy

353. Which tool is associated with mathematical computation and experimentation?

A. SageMath
B. RBAC
C. MAC
D. Smart card

[PB] Professor's MCQ bank (user-supplied file), original Q256 · Difficulty: Easy

Previous-exam questions (2015–2019)

354. If C=E2(E1(P,k1), k2), the cipher that provide C is called a …….. cipher.

A. symmetric
B. public-key
C. columnar transposition
D. Product

[PE] Previous exams 2016-17 & 2017-18 (Q7) · Difficulty: Medium

355. MD5 is ……. of message.

A. a symmetric encryption
B. a hash function
C. an asymmetric encryption
D. product encryption

[PE] Previous exams 2016-17 & 2017-18 (Q8) · Difficulty: Easy

356. MD5 is digest a message of any size to a …….. digest.

A. 128-bit digest
B. 256-bit
C. 156-bit
D. 160-bit

[PE] Previous exams 2016-17 & 2017-18 (Q9) · Difficulty: Easy

357. SHA is produces a ……. digest of message.

A. 128-bit digest
B. 256-bit
C. 156-bit
D. 160-bit

[PE] Previous exams 2016-17 & 2017-18 (Q10) · Difficulty: Easy

358. Some an advantage of a stream cipher is …….

A. high error propagation
B. speed transformation
C. High diffusion
D. all true

[PE] Previous exams 2015-16 & 2018-19 (Q10/Q10) · Difficulty: Easy

359. Some an advantage of a block cipher is …….

A. High diffusion.
B. Immunity to insertion of symbols.
C. a & b
D. high speed transformation

[PE] Previous exams 2015-16 & 2018-19 (Q11/Q11) · Difficulty: Easy

360. For ....., the attack is able to find two plaintexts that produce the same hash digest in approximately 2^63 steps.

A. Md5

B. MD4

C. SHS

D. SHA

[PE] Previous exams 2015-16 & 2018-19 (Q13/Q13) · Difficulty: Hard

Original practice questions

361. Encrypting “HELLO” with a Caesar shift of 1 gives ...

A. IFMMP

B. GDKKN

C. HELLO

D. JGNNQ

[OR] Original practice question (written for this package) · Difficulty: Easy

362. Decrypt “KHOOR” (Caesar, shift 3).

A. HELLO

B. WORLD

C. LIPPS

D. KHOOR

[OR] Original practice question (written for this package) · Difficulty: Medium

363. Which classical cipher is NOT a substitution cipher?

A. Caesar

B. Vigenère

C. Playfair

D. Rail Fence

[OR] Original practice question (written for this package) · Difficulty: Medium

364. Why is the one-time pad rarely used in practice?

A. It is breakable

B. Key distribution: the key must be as long as the message and never reused

C. It is too fast

D. It has no key

[OR] Original practice question (written for this package) · Difficulty: Medium

365. Substitution mainly provides ... and transposition mainly provides ...

A. diffusion; confusion

B. confusion; diffusion

C. integrity; availability

D. hashing; signing

[OR] Original practice question (written for this package) · Difficulty: Medium

366. How many keys are needed for 6 users to communicate pairwise with symmetric encryption?

A. 6
B. 12
C. 15
D. 30

[OR] Original practice question (written for this package) · Difficulty: Easy

367. How many keys (public+private) are needed for 6 users in a public-key system?

A. 6
B. 12
C. 15
D. 36

[OR] Original practice question (written for this package) · Difficulty: Easy

368. Which key does Bob use to read a message Alice encrypted for him using public-key encryption?

A. Alice’s public key
B. Bob’s private key
C. Alice’s private key
D. Bob’s public key

[OR] Original practice question (written for this package) · Difficulty: Medium

369. Which provides authenticity of the sender in public-key systems?

A. Encrypting with the sender’s private key (signing)
B. Encrypting with the receiver’s public key
C. Salting
D. Padding

[OR] Original practice question (written for this package) · Difficulty: Medium

370. RSA with p=5, q=11, e=3. What is d?

A. 7
B. 27
C. 3
D. 13

[OR] Original practice question (written for this package) · Difficulty: Medium

371. RSA with n=33, e=3, d=7: encrypt M=2.

A. 8
B. 6
C. 14
D. 2

[OR] Original practice question (written for this package) · Difficulty: Medium

372. Which is true about DES?

A. 64-bit block, 56-bit effective key, 16 rounds

B. 128-bit block, 10 rounds

C. asymmetric

D. uses 4096-bit key

[OR] Original practice question (written for this package) · Difficulty: Medium

373. AES with a 256-bit key uses ... rounds.

A. 10

B. 12

C. 14

D. 16

[OR] Original practice question (written for this package) · Difficulty: Medium

374. Which AES step is a transposition (provides diffusion)?

A. SubBytes

B. ShiftRows

C. AddRoundKey

D. Key expansion

[OR] Original practice question (written for this package) · Difficulty: Medium

375. A stream cipher is preferable when ...

A. data arrive in unpredictable bursts and must be encrypted immediately

B. maximum diffusion is required

C. padding is desired

D. insertion of symbols must be detected

[OR] Original practice question (written for this package) · Difficulty: Medium

376. A one-bit error in one ciphertext block of a block cipher typically affects ...

A. only that bit

B. the decryption of the whole block

C. nothing

D. all future blocks always

[OR] Original practice question (written for this package) · Difficulty: Medium

377. Which function is one-way and gives a fixed-size output?

A. AES

B. RSA

C. SHA

D. Caesar

[OR] Original practice question (written for this package) · Difficulty: Easy

378. A digital certificate is signed by ...

A. the user himself only
B. a certificate authority
C. the receiver
D. the network administrator only

[OR] Original practice question (written for this package) · Difficulty: Medium

379. Why can Diffie–Hellman alone be attacked by a man-in-the-middle?

A. It uses long keys
B. It does not authenticate the parties
C. It is symmetric
D. It uses hashes

[OR] Original practice question (written for this package) · Difficulty: Hard

380. Which provides confidentiality AND sender authenticity in a message from S to R?

A. E(kPUB-R, E(kPRIV-S, M))
B. E(kPUB-S, M)
C. only a hash
D. only a salt

[OR] Original practice question (written for this package) · Difficulty: Medium

381. In a public-key system with 100 users, how many individual keys exist in total?

A. 100
B. 200
C. 4950
D. 9900

[OR] Original practice question (written for this package) · Difficulty: Medium

382. In symmetric cryptography with 100 users, the number of pairwise keys is ...

A. 100
B. 200
C. 4950
D. 9900

[OR] Original practice question (written for this package) · Difficulty: Medium

Chapter 3 — Programs and Programming

Program flaws and buffer overflows

383. Why is protecting programs at the heart of computer security?

A. Programs only store passwords.

B. Programs constitute a large part of computing systems.

C. Programs cannot access memory.

D. Programs do not interact with operating systems.

[PB] Professor's MCQ bank (user-supplied file), original Q257 · Difficulty: Easy

384. What is a programming flaw?

A. A security policy.

B. A defect in a program that may cause incorrect or unsafe behavior.

C. A hardware upgrade.

D. A type of network cable.

[PB] Professor's MCQ bank (user-supplied file), original Q258 · Difficulty: Easy

385. Which of the following describes an intentional flaw?

A. A defect introduced deliberately.

B. A defect caused only by hardware failure.

C. A defect introduced accidentally.

D. A correct programming instruction.

[PB] Professor's MCQ bank (user-supplied file), original Q259 · Difficulty: Easy

386. Which of the following describes an inadvertent flaw?

A. A defect introduced intentionally.

B. A defect introduced unintentionally.

C. A security control.

D. A hardware protection mechanism.

[PB] Professor's MCQ bank (user-supplied file), original Q260 · Difficulty: Easy

387. Which term refers to a weakness that an attacker may exploit?

A. Countermeasure.

B. Vulnerability.

C. Documentation.

D. Availability.

[PB] Professor's MCQ bank (user-supplied file), original Q261 · Difficulty: Easy

388. What does a countermeasure do?

A. Always creates a vulnerability.
B. Prevents, detects, or reduces the impact of a security problem.
C. Disables all system functions.
D. Removes the need for security testing.

[PB] Professor's MCQ bank (user-supplied file), original Q262 · Difficulty: Easy

389. What is a buffer?

A. An allocated segment of memory.
B. A user account.
C. A network connection.
D. A security policy.

[PB] Professor's MCQ bank (user-supplied file), original Q263 · Difficulty: Easy

390. A buffer overflow occurs when:

A. A program writes within the allocated memory boundaries.
B. A program writes beyond the allocated buffer boundaries.
C. A program closes a file.
D. A user changes a password.

[PB] Professor's MCQ bank (user-supplied file), original Q264 · Difficulty: Easy

391. Consider the following declaration: char sample[10]; Which index is outside the valid array boundaries?

A. sample[0]
B. sample[5]
C. sample[9]
D. sample[10]

[PB] Professor's MCQ bank (user-supplied file), original Q265 · Difficulty: Medium

392. Which memory area is commonly associated with dynamically allocated data?

A. Stack.
B. Heap.
C. Program Counter.
D. Return Address.

[PB] Professor's MCQ bank (user-supplied file), original Q266 · Difficulty: Easy

393. Which memory area stores information associated with procedure calls and returns?

A. Stack.
B. Heap.
C. Network buffer only.
D. Disk partition.

[PB] Professor's MCQ bank (user-supplied file), original Q267 · Difficulty: Easy

394. What does the Program Counter identify?

A. The password of the current user.
B. The address of the next instruction to execute.
C. The size of the heap.
D. The number of files on disk.

[PB] Professor's MCQ bank (user-supplied file), original Q268 · Difficulty: Easy

395. What is the purpose of a return address?

A. To identify the next user account.
B. To determine where execution resumes after a procedure returns.
C. To allocate disk space.
D. To validate a date.

[PB] Professor's MCQ bank (user-supplied file), original Q269 · Difficulty: Easy

396. What is a possible consequence of a buffer overflow?

A. It always improves performance.
B. It may overwrite adjacent memory and affect program execution.
C. It always deletes the operating system.
D. It cannot affect security.

[PB] Professor's MCQ bank (user-supplied file), original Q270 · Difficulty: Easy

397. Which of the following may be affected by an overflow, according to the lecture's memory examples?

A. Only the keyboard.
B. Only the monitor.
C. Another data item, an instruction, another program's data or code, or operating-system data or code.
D. Only the network cable.

[PB] Professor's MCQ bank (user-supplied file), original Q271 · Difficulty: Medium

398. What is privilege escalation?

A. Reducing the number of program instructions.
B. Gaining higher privileges than originally permitted.
C. Reducing the amount of allocated memory.
D. Checking array boundaries.

[PB] Professor's MCQ bank (user-supplied file), original Q272 · Difficulty: Easy

399. How may a buffer overflow affect the stack?

A. By changing a return address or other stack information.
B. By automatically repairing all program defects.
C. By changing the physical keyboard.
D. By preventing all procedure calls.

[PB] Professor's MCQ bank (user-supplied file), original Q273 · Difficulty: Medium

400. Which of the following is an overflow countermeasure?

A. Accepting unlimited input.
B. Ignoring array boundaries.
C. Checking lengths before writing.
D. Disabling code review.

[PB] Professor's MCQ bank (user-supplied file), original Q274 · Difficulty: Easy

401. Which of the following helps detect unsafe conditions in source code?

A. Static code analyzer.
B. Word processor.
C. Media player.
D. File compression tool.

[PB] Professor's MCQ bank (user-supplied file), original Q275 · Difficulty: Easy

402. Which programming languages are mentioned in the lecture as providing bounds-checking features?

A. Java, .NET, Perl, and Python.
B. HTML, CSS, and SQL only.
C. Assembly only.
D. C and C++ only.

[PB] Professor's MCQ bank (user-supplied file), original Q276 · Difficulty: Easy

403. Which languages are described in the lecture as allowing largely unchecked memory access?

A. Java and Python.
B. C, C++, and Assembly.
C. HTML and CSS.
D. SQL and XML.

[PB] Professor's MCQ bank (user-supplied file), original Q277 · Difficulty: Easy

404. What is the purpose of a canary in stack protection?

A. To increase the size of the program.
B. To help detect unexpected stack corruption.
C. To encrypt all network traffic.
D. To replace the compiler.

[PB] Professor's MCQ bank (user-supplied file), original Q278 · Difficulty: Medium

405. Which statement best describes the responsibility for preventing buffer overflows?

A. Only the end user is responsible.
B. Only the operating system is responsible.
C. The programmer, operating system, compiler, and hardware share responsibility.
D. No component can help prevent them.

[PB] Professor's MCQ bank (user-supplied file), original Q279 · Difficulty: Medium

406. What is the purpose of limiting a program's privileges?

A. To ensure that every process becomes an administrator.

B. To reduce the damage if the program is compromised.

C. To disable input validation.

D. To remove the need for memory protection.

[PB] Professor's MCQ bank (user-supplied file), original Q280 · Difficulty: Easy

407. Which programming error occurs when an array boundary or count is one greater or one less than intended?

A. Integer overflow.

B. Off-by-one error.

C. Complete mediation.

D. Virus signature.

[PB] Professor's MCQ bank (user-supplied file), original Q281 · Difficulty: Easy

408. What is integer overflow?

A. An arithmetic result exceeds the representable range of an integer type.

B. A string contains a valid null terminator.

C. A program performs a successful backup.

D. A user enters the correct password.

[PB] Professor's MCQ bank (user-supplied file), original Q282 · Difficulty: Medium

409. What is an unterminated null-terminated string?

A. A string containing only numbers.

B. A string missing its required null character terminator.

C. A string with too many spaces only.

D. A string stored exclusively on a network.

[PB] Professor's MCQ bank (user-supplied file), original Q283 · Difficulty: Medium

Mediation, reference monitor, TOCTTOU

410. What does mediation mean in access control?

A. Checking whether a subject is authorized to perform an operation on an object.

B. Encrypting every file automatically.

C. Increasing the speed of a processor.

D. Deleting all user accounts.

[PB] Professor's MCQ bank (user-supplied file), original Q284 · Difficulty: Easy

411. In access control, what is a subject?

A. The resource being accessed.

B. The entity requesting access.

C. A type of malware.

D. A memory address.

[PB] Professor's MCQ bank (user-supplied file), original Q285 · Difficulty: Easy

412. In access control, what is an object?

A. The entity requesting access.
B. The resource that a subject wants to access.
C. A type of password.
D. A program counter.

[PB] Professor's MCQ bank (user-supplied file), original Q286 · Difficulty: Easy

413. Incomplete mediation occurs when:

A. Every access is checked appropriately.
B. An application accepts incorrect input or fails to perform adequate checks.
C. A system performs a backup.
D. A program closes normally.

[PB] Professor's MCQ bank (user-supplied file), original Q287 · Difficulty: Easy

414. What is the main purpose of input validation?

A. To accept all possible inputs.
B. To ensure that input data satisfy the required rules and constraints.
C. To remove all user permissions.
D. To prevent users from accessing the interface.

[PB] Professor's MCQ bank (user-supplied file), original Q288 · Difficulty: Easy

415. Which of the following is an example of invalid input?

A. 2009Jan17
B. 2024Feb20
C. 1800Feb30
D. 2025Mar15

[PB] Professor's MCQ bank (user-supplied file), original Q289 · Difficulty: Easy

416. Why should a web application not trust a price passed in a URL?

A. URLs cannot contain numbers.
B. A user may modify the price before submitting the request.
C. Prices must always be negative.
D. The browser prevents every possible modification.

[PB] Professor's MCQ bank (user-supplied file), original Q290 · Difficulty: Medium

417. Which statement expresses the principle emphasized in the lecture?

A. If data are displayed, they cannot be changed.
B. If data can be changed, assume they have been.
C. Users never make mistakes.
D. Browser validation is always sufficient.

[PB] Professor's MCQ bank (user-supplied file), original Q291 · Difficulty: Medium

418. Which of the following is a property of a reference monitor?

A. It must always be bypassable.
B. It must be invoked only occasionally.
C. It must be small and simple enough to support confidence in its correctness.
D. It must allow every user unrestricted access.

[PB] Professor's MCQ bank (user-supplied file), original Q292 · Difficulty: Medium

419. What does Unbypassable mean?

A. The access-control mechanism cannot be bypassed.
B. The mechanism is never executed.
C. The mechanism accepts every request.
D. The mechanism operates only during backups.

[PB] Professor's MCQ bank (user-supplied file), original Q293 · Difficulty: Medium

420. What does Always Invoked mean for a reference monitor?

A. It checks access only after an incident.
B. It is invoked whenever the relevant access check is required.
C. It is invoked only when the administrator logs in.
D. It checks only network traffic.

[PB] Professor's MCQ bank (user-supplied file), original Q294 · Difficulty: Medium

421. What does TOCTTOU stand for?

A. Time-of-Check to Time-of-Use.
B. Type-of-Code to Type-of-User.
C. Transfer-of-Control to Transfer-of-User.
D. Time-of-Copy to Time-of-Update.

[PB] Professor's MCQ bank (user-supplied file), original Q295 · Difficulty: Easy

422. A TOCTTOU vulnerability occurs when:

A. A program validates data and the data never change.
B. A condition changes after checking but before using the result.
C. A program uses no memory.
D. A user creates a strong password.

[PB] Professor's MCQ bank (user-supplied file), original Q296 · Difficulty: Medium

423. TOCTTOU is associated with which general issue?

A. Synchronization and timing.
B. Image compression.
C. Password length only.
D. Screen resolution.

[PB] Professor's MCQ bank (user-supplied file), original Q297 · Difficulty: Easy

424. Which security failures may result from a TOCTTOU vulnerability?

A. Confidentiality failure only in every case.
B. Integrity failure only in every case.
C. Confidentiality failure, integrity failure, or both.
D. Neither confidentiality nor integrity can be affected.

[PB] Professor's MCQ bank (user-supplied file), original Q298 · Difficulty: Medium

425. Which is a possible TOCTTOU countermeasure?

A. Allowing users to change critical data after validation.
B. Copying request data into a protected area before validation.
C. Ignoring access-control checks.
D. Trusting old validation results indefinitely.

[PB] Professor's MCQ bank (user-supplied file), original Q299 · Difficulty: Medium

426. What does serial integrity aim to protect in the TOCTTOU context?

A. The continuity and integrity of a sensitive operation.
B. The physical appearance of the computer.
C. The number of installed applications.
D. The length of a password.

[PB] Professor's MCQ bank (user-supplied file), original Q300 · Difficulty: Hard

427. What is a race condition?

A. A defect whose outcome depends on the timing or ordering of concurrent activities.
B. A type of backup.
C. A password policy.
D. A form of input validation.

[PB] Professor's MCQ bank (user-supplied file), original Q301 · Difficulty: Medium

Trapdoors / backdoors

428. An undocumented access point is also called:

A. Heap.
B. Backdoor or Trapdoor.
C. Stack Pointer.
D. Virus Signature.

[PB] Professor's MCQ bank (user-supplied file), original Q302 · Difficulty: Easy

429. Why might a developer create a trapdoor during program development?

A. To support testing or inspect internal program behavior.
B. To increase the monitor's size.
C. To prevent all debugging.
D. To eliminate the need for source code.

[PB] Professor's MCQ bank (user-supplied file), original Q303 · Difficulty: Easy

430. Which is a possible reason a trapdoor remains in a production system?

A. The developer forgets to remove it.
B. The computer has a keyboard.
C. The system contains a database.
D. The program has comments.

[PB] Professor's MCQ bank (user-supplied file), original Q304 · Difficulty: Easy

431. Why can a backdoor be dangerous?

A. It always improves security.
B. It may provide access outside the system's normal access procedures.
C. It prevents all unauthorized access automatically.
D. It cannot affect production systems.

[PB] Professor's MCQ bank (user-supplied file), original Q305 · Difficulty: Easy

Malicious code and countermeasures

432. What does malware mean?

A. Managed hardware.
B. Malicious software.
C. Memory allocation.
D. Machine language.

[PB] Professor's MCQ bank (user-supplied file), original Q306 · Difficulty: Easy

433. Which of the following best describes malicious code?

A. Code deliberately introduced to cause undesirable effects.
B. Code used exclusively for documentation.
C. Code that cannot execute.
D. Code that always protects data.

[PB] Professor's MCQ bank (user-supplied file), original Q307 · Difficulty: Easy

434. Which of the following is an example of a malware trigger?

A. A specified date.
B. A specified event.
C. A specified condition.
D. All of the above.

[PB] Professor's MCQ bank (user-supplied file), original Q308 · Difficulty: Easy

435. Which statement best defines a computer virus?

A. A program that replicates by modifying other programs.
B. A program used only to validate dates.
C. A program that can never replicate.
D. A hardware component.

[PB] Professor's MCQ bank (user-supplied file), original Q309 · Difficulty: Easy

436. Which virus depends on its host program and generally operates while the host is running?

A. Resident virus.
B. Transient virus.
C. Worm.
D. Rabbit.

[PB] Professor's MCQ bank (user-supplied file), original Q310 · Difficulty: Medium

437. Which virus can remain active in memory after the associated program ends?

A. Transient virus.
B. Resident virus.
C. Time bomb.
D. Trojan horse.

[PB] Professor's MCQ bank (user-supplied file), original Q311 · Difficulty: Medium

438. What is the defining characteristic of a Trojan horse in the lecture?

A. It spreads copies of itself through a network.
B. It has a second, nonobvious malicious effect.
C. It activates only at midnight.
D. It always exhausts disk space.

[PB] Professor's MCQ bank (user-supplied file), original Q312 · Difficulty: Easy

439. A logic bomb activates when:

A. A specified condition occurs.
B. A computer is manufactured.
C. A monitor is replaced.
D. A file is printed in every case.

[PB] Professor's MCQ bank (user-supplied file), original Q313 · Difficulty: Easy

440. A time bomb is a type of logic bomb triggered by:

A. A particular time or date.
B. A particular screen size.
C. A particular keyboard layout.
D. A particular file extension only.

[PB] Professor's MCQ bank (user-supplied file), original Q314 · Difficulty: Easy

441. Which malicious program spreads copies of itself through a network?

A. Worm.
B. Canary.
C. Reference monitor.
D. Static code analyzer.

[PB] Professor's MCQ bank (user-supplied file), original Q315 · Difficulty: Easy

442. What is a rabbit designed to do?

A. Improve authentication.
B. Exhaust computing resources through uncontrolled replication.
C. Detect array boundaries.
D. Validate user identities.

[PB] Professor's MCQ bank (user-supplied file), original Q316 · Difficulty: Easy

443. What is ransomware commonly designed to do?

A. Encrypt data and demand payment.
B. Check source code for errors.
C. Improve memory allocation.
D. Validate all URL parameters.

[PB] Professor's MCQ bank (user-supplied file), original Q317 · Difficulty: Easy

444. What is the main purpose of a rootkit?

A. To make malicious activity difficult to detect or help maintain access.
B. To validate dates.
C. To check array boundaries.
D. To improve document formatting.

[PB] Professor's MCQ bank (user-supplied file), original Q318 · Difficulty: Medium

445. What does a keystroke logger record?

A. The keys pressed by a user.
B. The size of the monitor.
C. The temperature of the processor only.
D. The number of installed printers.

[PB] Professor's MCQ bank (user-supplied file), original Q319 · Difficulty: Easy

446. What is phishing?

A. A deceptive technique used to trick people into revealing sensitive information or taking unsafe actions.
B. A memory-allocation technique.
C. A type of array.
D. A software-testing phase.

[PB] Professor's MCQ bank (user-supplied file), original Q320 · Difficulty: Easy

447. Vishing is most closely associated with:

A. Voice-based or telephone phishing.
B. Buffer allocation.
C. Static code analysis.
D. Disk formatting.

[PB] Professor's MCQ bank (user-supplied file), original Q321 · Difficulty: Easy

448. Which set represents the four aspects used to study malicious-code infections?

A. Harm, Transmission and Propagation, Activation, Stealth.

B. Design, Printing, Formatting, Documentation.

C. Authentication, Printing, Backup, Deletion.

D. Input, Output, Display, Storage.

[PB] Professor's MCQ bank (user-supplied file), original Q322 · Difficulty: Easy

449. Which aspect describes how malicious code spreads and causes additional infections?

A. Harm.

B. Transmission and Propagation.

C. Activation.

D. Stealth.

[PB] Professor's MCQ bank (user-supplied file), original Q323 · Difficulty: Easy

450. Which aspect describes how malicious code conceals its presence to avoid detection?

A. Harm.

B. Activation.

C. Stealth.

D. Transmission.

[PB] Professor's MCQ bank (user-supplied file), original Q324 · Difficulty: Easy

451. What is a virus signature?

A. A recognizable pattern used to identify a known virus.

B. A user's handwritten signature.

C. A password policy.

D. A network cable.

[PB] Professor's MCQ bank (user-supplied file), original Q325 · Difficulty: Easy

452. What is one limitation of signature-based virus scanners?

A. They never require updates.

B. New malware may not match existing signatures.

C. They cannot search files.

D. They automatically detect every possible threat.

[PB] Professor's MCQ bank (user-supplied file), original Q326 · Difficulty: Medium

453. What does an IDS primarily do?

A. Detects suspicious activity or intrusions.

B. Prevents every possible attack automatically.

C. Allocates memory.

D. Validates dates only.

[PB] Professor's MCQ bank (user-supplied file), original Q327 · Difficulty: Easy

454. What does an IPS primarily do?

A. Records keystrokes only.
B. Prevents or blocks detected malicious activity according to its capabilities and policies.
C. Stores return addresses.
D. Checks whether a date is valid.

[PB] Professor's MCQ bank (user-supplied file), original Q328 · Difficulty: Medium

455. What is a man-in-the-middle attack?

A. An attacker intervenes between communicating parties to monitor or manipulate communication.
B. A program checks array boundaries.
C. A user changes a desktop background.
D. A backup system restores files.

[PB] Professor's MCQ bank (user-supplied file), original Q329 · Difficulty: Easy

456. What is a timing attack?

A. An attack that uses information about execution time to infer sensitive information.
B. An attack that always requires physical damage.
C. A backup procedure.
D. A type of array-boundary check.

[PB] Professor's MCQ bank (user-supplied file), original Q330 · Difficulty: Medium

457. What is a covert channel?

A. A hidden communication path that may be used to transfer information.
B. A public documentation page.
C. A type of program counter.
D. A compiler warning.

[PB] Professor's MCQ bank (user-supplied file), original Q331 · Difficulty: Medium

458. What is a rootkit's concealment capability primarily intended to achieve?

A. Make malicious activity harder to discover.
B. Make all data public.
C. Prevent every program from running.
D. Remove the need for authentication.

[PB] Professor's MCQ bank (user-supplied file), original Q332 · Difficulty: Easy

459. Which of the following is an example of interface illusion?

A. A fake web page made to appear genuine.
B. A correct date entered in a form.
C. A secure array access.
D. A successful system backup.

[PB] Professor's MCQ bank (user-supplied file), original Q333 · Difficulty: Easy

460. What is the purpose of a salami attack, in its general security meaning?

A. To accumulate small unauthorized gains or changes that may be difficult to notice individually.
B. To check array boundaries.
C. To validate all user identities.
D. To improve system backups.

[PB] Professor's MCQ bank (user-supplied file), original Q334 · Difficulty: Medium

461. What is social engineering?

A. Manipulating people into revealing information or performing unsafe actions.
B. Allocating memory dynamically.
C. Checking a program's syntax.
D. Updating a compiler.

[PB] Professor's MCQ bank (user-supplied file), original Q335 · Difficulty: Easy

462. What does a clean desk policy require?

A. Leaving sensitive documents exposed.
B. Securing sensitive documents instead of leaving them exposed.
C. Disabling authentication.
D. Sharing passwords with colleagues.

[PB] Professor's MCQ bank (user-supplied file), original Q336 · Difficulty: Easy

463. What does a clean screen policy require?

A. Leaving sensitive information visible.
B. Locking the screen or preventing sensitive information from remaining visible when unattended.
C. Disabling screen protection.
D. Displaying passwords publicly.

[PB] Professor's MCQ bank (user-supplied file), original Q337 · Difficulty: Easy

464. Which is a recommended password practice?

A. Reusing the same password everywhere.
B. Using strong passwords and avoiding reuse across different services.
C. Sharing passwords publicly.
D. Writing passwords into public documents.

[PB] Professor's MCQ bank (user-supplied file), original Q338 · Difficulty: Easy

465. Which practice helps reduce malware infection risk?

A. Installing software from untrusted sources without checking it.
B. Keeping anti-malware tools updated and being cautious with suspicious attachments.
C. Disabling all security controls.
D. Ignoring software updates.

[PB] Professor's MCQ bank (user-supplied file), original Q339 · Difficulty: Easy

466. Why are backups important?

A. They eliminate every vulnerability.
B. They can help restore data after an incident.
C. They prevent all phishing attacks.
D. They replace authentication.

[PB] Professor's MCQ bank (user-supplied file), original Q340 · Difficulty: Easy

SSDLC and security requirements

467. What is SSDLC?

A. Secure Software Development Life Cycle.
B. Standard System Data Level Control.
C. Software Storage and Disk Loading Code.
D. Secure Server Data Link Connection.

[PB] Professor's MCQ bank (user-supplied file), original Q341 · Difficulty: Easy

468. What is the main goal of SSDLC?

A. To consider security only after deployment.
B. To integrate security activities throughout the software development process.
C. To eliminate all testing.
D. To give every user administrator privileges.

[PB] Professor's MCQ bank (user-supplied file), original Q342 · Difficulty: Easy

469. Which of the following is a phase of SSDLC?

A. Security Requirements.
B. Security Design.
C. Security Testing.
D. All of the above.

[PB] Professor's MCQ bank (user-supplied file), original Q343 · Difficulty: Easy

470. What is a security requirement?

A. A requirement that supports the security objectives of a system.
B. A requirement to remove all access controls.
C. A requirement to avoid testing.
D. A requirement to make all files public.

[PB] Professor's MCQ bank (user-supplied file), original Q344 · Difficulty: Easy

471. Which security requirement is most directly concerned with preventing unauthorized modification of data?

A. Integrity requirement.
B. Privacy requirement.
C. Physical protection requirement.
D. Documentation requirement.

[PB] Professor's MCQ bank (user-supplied file), original Q348 · Difficulty: Easy

472. Which security requirement concerns recording and reviewing security-related activities?

A. Security auditing requirement.
B. Portability requirement.
C. Usability requirement.
D. Scalability requirement.

[PB] Professor's MCQ bank (user-supplied file), original Q349 · Difficulty: Easy

473. Which requirement concerns protecting personal information?

A. Privacy requirement.
B. Integer overflow.
C. Buffer overflow.
D. Stack pointer.

[PB] Professor's MCQ bank (user-supplied file), original Q350 · Difficulty: Easy

474. Which requirement concerns maintaining essential services despite failures or attacks?

A. Survivability requirement.
B. Authentication requirement.
C. Input validation.
D. Virus signature.

[PB] Professor's MCQ bank (user-supplied file), original Q351 · Difficulty: Medium

Mixed review (incl. NOT questions)

475. Which of the following is NOT a reference monitor property?

A. Small and simple enough.
B. Unbypassable.
C. Always invoked.
D. Must accept all access requests.

[PB] Professor's MCQ bank (user-supplied file), original Q352 · Difficulty: Medium

476. Which of the following is NOT a recommended buffer overflow countermeasure?

A. Check lengths before writing.
B. Confirm array subscripts are within limits.
C. Limit the program's privileges.
D. Ignore boundary conditions.

[PB] Professor's MCQ bank (user-supplied file), original Q353 · Difficulty: Easy

477. Which statement best distinguishes a virus from a worm?

A. A virus commonly modifies other programs, while a worm spreads copies of itself through a network.
B. A virus only uses networks, while a worm only modifies host files.
C. Both terms always mean exactly the same thing.
D. Neither can replicate.

[PB] Professor's MCQ bank (user-supplied file), original Q354 · Difficulty: Medium

478. Which statement about logic bombs is correct?

A. Every logic bomb is necessarily a time bomb.

B. A logic bomb activates when a specified condition occurs.

C. A logic bomb is a memory register.

D. A logic bomb always performs backups.

[PB] Professor's MCQ bank (user-supplied file), original Q355 · Difficulty: Medium

479. Which of the following is NOT one of the four aspects used to study malicious-code infections?

A. Harm.

B. Transmission and Propagation.

C. Activation.

D. Authentication.

[PB] Professor's MCQ bank (user-supplied file), original Q356 · Difficulty: Easy

480. Which measure directly reduces the consequences of a program compromise caused by excessive privileges?

A. Least privilege.

B. Password reuse.

C. Disabling validation.

D. Removing all monitoring.

[PB] Professor's MCQ bank (user-supplied file), original Q357 · Difficulty: Easy

481. Which of the following is most closely associated with malware concealment?

A. Stealth.

B. Activation.

C. Input validation.

D. Memory allocation.

[PB] Professor's MCQ bank (user-supplied file), original Q358 · Difficulty: Easy

482. Which of the following is a security requirement rather than a memory structure?

A. Stack.

B. Heap.

C. Privacy requirement.

D. Return address.

[PB] Professor's MCQ bank (user-supplied file), original Q359 · Difficulty: Easy

483. Which activity belongs to the maintenance phase of SSDLC?

A. Addressing security issues and maintaining the system after deployment.

B. Ignoring newly discovered vulnerabilities.

C. Removing all testing.

D. Allowing unauthorized access.

[PB] Professor's MCQ bank (user-supplied file), original Q360 · Difficulty: Easy

Previous-exam questions (2015–2019)

484. A failure can be discovered before or after system delivery, during ……..

A. testing,
B. operation and maintenance.
C. analysis
D. a or b

[PE] Previous exams 2016-17 & 2017-18 (Q20) · Difficulty: Easy

485. A bug can be a mistake in ……..

A. interpreting a requirement
B. a syntax error in a piece of code
C. the (as-yet-unknown) cause of a system crash
D. all true

[PE] Previous exams 2016-17 & 2017-18 (Q21) · Difficulty: Easy

486. unexpected behavior of the code is called a …….

A. program security flaw
B. program error
C. program test
D. all false

[PE] Previous exams 2016-17 & 2017-18 (Q22) · Difficulty: Easy

487. A …….. is/are nonmalicious program error(s).

A. Security Implication
B. salami attack
C. Incomplete mediation
D. a & c

[PE] Previous exams 2016-17 & 2017-18 & Previous exams 2015-16 & 2018-19 (Q23 / Q21 / Q23) · Difficulty: Medium

488. A ……. is/are nonmalicious program error(s).

A. salami attack
B. buffer overflow
C. Trojan horse
D. b & c

[PE] Previous exams 2015-16 & 2018-19 (Q21/Q20) · Difficulty: Easy

489. ……. is a spoofing attack in which all or part of a web page is false.

A. a covert channels
B. a trapdoors
C. an interface illusions
D. all false

[PE] Previous exams 2016-17 & 2017-18 (Q24) · Difficulty: Easy

490. In the inadvertent flaws, the flaw that result from serialization and aliasing is a .....

A. basis for authorization
B. permission checks
C. program flow order
D. controlled access to data

[PE] Previous exams 2015-16 & 2018-19 (Q22) · Difficulty: Medium

491. In performing some software activity, the error may lead to a .....

A. a fault, an incorrect step, command
B. process and data definition in a computer program
C. a failure
D. a & b

[PE] Previous exams 2015-16 & 2018-19 (Q14/Q14) · Difficulty: Medium

492. A failure is ..... of the system.

A. an inside view
B. user view
C. outside view
D. b & c

[PE] Previous exams 2015-16 & 2018-19 (Q15/Q15) · Difficulty: Easy

493. When a more faults were discovered and fixed in the system is better than when a few faults were discovered and fixed. That mean a .....

A. design of a system is good
B. more rigorous analysis and testing are performed
C. design of a system is not good
D. b &c.

[PE] Previous exams 2015-16 & 2018-19 (Q17/Q16) · Difficulty: Hard

494. During the system ..... phase, a developer ensure that the system is meets the requirements and implements the solution as called for in the design.

A. specification
B. designing
C. implementation
D. testing

[PE] Previous exams 2015-16 & 2018-19 (Q18/Q17) · Difficulty: Easy

495. malicious people can make programs serve as vehicles to .....

A. access to the system
B. change data
C. change programs
D. all true

[PE] Previous exams 2015-16 & 2018-19 (Q19/Q18) · Difficulty: Easy

496. A virus can ..... to cause an append to data.

A. attach to executable program
B. attach to data or control file
C. infect disks
D. spread infection

[PE] Previous exams 2015-16 & 2018-19 (Q20/Q19) · Difficulty: Easy

497. ..... is desirable because developers cannot easily and maliciously alter the components of others if they do not know how the components work.

A. Encapsulation
B. Modularity
C. Coupling
D. Information hiding

[PE] Previous exams 2016-17 & 2017-18 (Q25) · Difficulty: Medium

498. ..... refers to the degree with which a component depends on other components in the system.

A. Encapsulation
B. Modularity
C. Coupling
D. Information hiding

[PE] Previous exams 2016-17 & 2017-18 (Q26) · Difficulty: Medium

Original practice questions

499. A human mistake that may lead to a fault is called a(n) ...

A. failure
B. error
C. attack
D. control

[OR] Original practice question (written for this package) · Difficulty: Easy

500. Which view corresponds to a fault?

A. outside/user view
B. inside/developer view
C. legal view
D. network view

[OR] Original practice question (written for this package) · Difficulty: Medium

501. Which is an inadvertent flaw category in Landwehr's taxonomy?

A. Trojan horse
B. Boundary condition violation
C. Logic bomb
D. Trapdoor

[OR] Original practice question (written for this package) · Difficulty: Medium

502. "Failure on the first or last case" corresponds to ...

A. validation error
B. domain error
C. boundary condition violation
D. serialization and aliasing

[OR] Original practice question (written for this package) · Difficulty: Medium

503. Writing 11 characters into a 10-byte buffer is ...

A. an off-by-one error only
B. a buffer overflow
C. a covert channel
D. a rootkit

[OR] Original practice question (written for this package) · Difficulty: Easy

504. Which language does NOT automatically check array bounds?

A. Java
B. Python
C. C
D. Perl

[OR] Original practice question (written for this package) · Difficulty: Medium

505. Overwriting the return address on the stack lets an attacker ...

A. redirect execution to attacker's code
B. speed up the program
C. encrypt the heap
D. validate input

[OR] Original practice question (written for this package) · Difficulty: Medium

506. A canary value placed before the return address is used to ...

A. detect stack corruption
B. encrypt traffic
C. authenticate users
D. allocate heap

[OR] Original practice question (written for this package) · Difficulty: Medium

507. An application trusts a hidden form field “discount=10%” that the user can edit. This is ...

A. incomplete mediation

B. TOCTTOU

C. a canary

D. a rootkit

[OR] Original practice question (written for this package) · Difficulty: Medium

508. Which input is invalid for a date field “YYYYMonDD”?

A. 2024Mar15

B. 2023Feb30

C. 2022Jan01

D. 2025Dec31

[OR] Original practice question (written for this package) · Difficulty: Medium

509. A file permission is checked, then replaced by a link to a protected file before it is opened. This is ...

A. TOCTTOU

B. a salami attack

C. phishing

D. a canary

[OR] Original practice question (written for this package) · Difficulty: Hard

510. Which is a TOCTTOU countermeasure?

A. Copy the request data to a protected area and validate the copy

B. Allow users to edit data after validation

C. Skip validation

D. Trust cached results forever

[OR] Original practice question (written for this package) · Difficulty: Medium

511. Trapdoors often remain because developers ...

A. forget to remove them

B. love security

C. use Java

D. run backups

[OR] Original practice question (written for this package) · Difficulty: Easy

512. Which malware spreads as a stand-alone program through networks?

A. Virus

B. Worm

C. Logic bomb

D. Keylogger

[OR] Original practice question (written for this package) · Difficulty: Easy

513. A program that behaves normally but also secretly sends your files to an attacker is a ...

A. Trojan horse
B. rabbit
C. canary
D. worm

[OR] Original practice question (written for this package) · Difficulty: Medium

514. A virus that stays active in memory after its host ends is ...

A. transient
B. resident
C. a worm
D. a bot

[OR] Original practice question (written for this package) · Difficulty: Medium

515. Which is a typical virus technique to hide itself?

A. Intercept system calls and falsify results
B. Print more pages
C. Increase CPU speed
D. Publish its source code

[OR] Original practice question (written for this package) · Difficulty: Medium

516. Signature-based antivirus cannot reliably detect ...

A. known viruses
B. brand-new malware with no signature yet
C. all files
D. backups

[OR] Original practice question (written for this package) · Difficulty: Medium

517. An IPS differs from an IDS because it can ...

A. only log events
B. block detected attacks
C. encrypt files
D. create passwords

[OR] Original practice question (written for this package) · Difficulty: Easy

518. Calling a victim and pretending to be the bank is ...

A. phishing by e-mail
B. vishing
C. salami attack
D. TOCTTOU

[OR] Original practice question (written for this package) · Difficulty: Medium

519. Rounding fractions of cents from many accounts into one account is a ...

A. salami attack
B. keystroke logger
C. timing attack
D. phishing

[OR] Original practice question (written for this package) · Difficulty: Medium

520. Which SSDLC phase comes right after security design?

A. Security development
B. Security maintenance
C. Security requirements
D. Security deployment

[OR] Original practice question (written for this package) · Difficulty: Medium

Legacy Topics

Legacy questions from 2015-16 / 2018-19

521. If a system component is isolated from the effects of other system components, this isolation called a .....

A. information hiding
B. encapsulation
C. modular
D. all true

[PE] Previous exams 2015-16 & 2018-19 (Q16) · Difficulty: Hard

522. The principle of isolating process spaces from each other is known as .....

A. Virtualization
B. Separation
C. Defense in depth
D. compartmentalization
E. All of the above

[PE] Previous exams 2015-16 & 2018-19 (Q4) · Difficulty: Medium

523. In Kerberos, a tickets that issued are secured with .....

A. symmetric cryptography
B. public-key cryptography
C. RSA
D. all false

[PE] Previous exams 2015-16 & 2018-19 (Q26) · Difficulty: Medium

524. In ..... separation, the different processes use different physical objects.

A. cryptographic
B. physical
C. temporal
D. all true

[PE] Previous exams 2015-16 & 2018-19 (Q27) · Difficulty: Easy

525. In ..... separation, the users operate under the illusion that no other processes exist.

A. cryptographic
B. physical
C. temporal
D. logical

[PE] Previous exams 2015-16 & 2018-19 (Q28) · Difficulty: Easy

526. A ..... is a method to confine users to one side of a boundary

A. fence register
B. fence
C. tagged architecture
D. b & c

[PE] Previous exams 2015-16 & 2018-19 (Q36) · Difficulty: Medium

527. In ....., user cannot identify certain areas of the program as inviolable

A. paging
B. fence
C. fence register
D. all false

[PE] Previous exams 2015-16 & 2018-19 (Q37) · Difficulty: Hard

528. A ..... uses with two or more users

A. base/bound register
B. fence
C. fence register
D. relocation

[PE] Previous exams 2015-16 & 2018-19 (Q38) · Difficulty: Hard

529. In ..... a user cannot generate an address or access to an unpermitted memory.

A. tagged architecture
B. base/bound register
C. segmentation
D. paging

[PE] Previous exams 2015-16 & 2018-19 (Q39) · Difficulty: Hard

530. The ..... offers implementation efficiency.

A. paging
B. base/bound register
C. segmentation
D. tagged architecture

[PE] Previous exams 2015-16 & 2018-19 (Q40) · Difficulty: Hard

Written Questions

Previous-exam written questions

531. Among the fundamental challenges in information security are confidentiality, integrity and availability. Give an example: (A) where confidentiality is more important than integrity; (B) where availability and integrity are more important than confidentiality; (C) describe an instance of a file that contains evidence of its own integrity and authenticity; (D) where availability is the overriding concern.

[PE] Previous exams: 2016-17 Q1; 2017-18 Q1; 2018-19 Q3 · Difficulty: Easy

532. List some properties that could mean a failure of data confidentiality.

[PE] Previous exams: 2016-17 Q2; 2017-18 Q2 · Difficulty: Easy

533. Compare between identification and authentication.

[PE] Previous exams: 2016-17 Q3A; 2017-18 Q3A; 2018-19 Q1A · Difficulty: Easy

534. What are the password guessing steps?

[PE] Previous exams: 2016-17 Q3B; 2017-18 Q3B (P.70); 2018-19 Q1B · Difficulty: Medium

535. What are the criteria to choose good passwords?

[PE] Previous exams: 2016-17 Q3C; 2017-18 Q3C (P.78); 2018-19 Q1C · Difficulty: Easy

536. What are the authentication biometrics advantages and the problems of using biometrics?

[PE] Previous exams: 2016-17 Q3D; 2018-19 Q1D · Difficulty: Medium

537. In brief, describe a federated identity management scheme with a figure.

[PE] Previous exams: 2016-17 Q3E · Difficulty: Medium

538. What are the differences between vulnerability, threats and control?

[PE] Previous exams: 2016-17 Q4; 2017-18 Q4 · Difficulty: Easy

539. There are several models of how access rights can be maintained and implemented by the reference monitor. What are these access controls?

[PE] Previous exams: 2016-17 Q5A · Difficulty: Medium

540. Compare between the access control directory and the access control list methods.

[PE] Previous exams: 2016-17 Q5B · Difficulty: Medium

541. In briefly, explain method, opportunity, and motive of the attackers.

[PE] Previous exams: 2016-17 Q6 · Difficulty: Easy

542. List the countermeasures with examples for each of them, and draw the figure that illustrates the types of countermeasures.

[PE] Previous exams: 2016-17 Q7; 2017-18 Q5 · Difficulty: Medium

543. In briefly, explain the AES algorithm.

[PE] Previous exams: 2016-17 Q8A; 2017-18 Q6A · Difficulty: Medium

544. Illustrate the RSA key setup. / In briefly, explain Rivest–Shamir–Adelman (RSA) encryption.

[PE] Previous exams: 2016-17 Q8B; 2017-18 Q6B; 2018-19 Q6A · Difficulty: Medium

545. What are the differences between stream and block ciphers? / Compare between stream ciphers and block ciphers.

[PE] Previous exams: 2016-17 Q8C; 2017-18 Q6C; 2018-19 Q6B · Difficulty: Medium

546. What are the advantages of the isolation of components?

[PE] Previous exams: 2016-17 Q9 (legacy) · Difficulty: Medium

547. What is the taxonomy of program flaws and what are the categories of each of them?

[PE] Previous exams: 2016-17 Q7(2nd); 2018-19 Q4 · Difficulty: Medium

548. What are the ways that we can deal with harm?

[PE] Previous exams: 2018-19 Q2 · Difficulty: Easy

549. What are the virus effects and how are they caused?

[PE] Previous exams: 2018-19 Q5 · Difficulty: Medium

Original written practice

550. Compare passive and active attacks (threatened properties, effect on the system, detection/prevention, examples).

[OR] Original practice question · Difficulty: Easy

551. Explain a buffer overflow. Describe how it can harm a system and list five countermeasures.

[OR] Original practice question · Difficulty: Medium

552. Explain incomplete mediation with a web example and say how to fix it.

[OR] Original practice question · Difficulty: Medium

553. Explain TOCTTOU, give an analogy or example, and list its countermeasures.

[OR] Original practice question · Difficulty: Medium

554. Compare DAC, MAC, RBAC and ABAC.

[OR] Original practice question · Difficulty: Medium

555. Compare symmetric and asymmetric encryption (keys, speed, key distribution, number of keys, uses).

[OR] Original practice question · Difficulty: Medium

556. Describe how a digital signature is created and verified, and which properties it provides.

[OR] Original practice question · Difficulty: Medium

557. Distinguish between a virus, a worm and a Trojan horse.

[OR] Original practice question · Difficulty: Easy

558. What is a salt and a rainbow table? Explain how the salt defeats the rainbow-table attack.

[OR] Original practice question · Difficulty: Medium

559. RSA exercise: p = 7, q = 13, e = 5. (a) Find n and φ(n). (b) Find d. (c) Encrypt M = 4. (d) Decrypt the result.

[OR] Original practice question · Difficulty: Hard

560. (a) How many symmetric keys are needed for 50 users to communicate pairwise? (b) How many keys in a public-key system?

[OR] Original practice question · Difficulty: Easy

561. Caesar cipher: (a) Encrypt “SECURITY” with k = 5. (b) Decrypt “WKH TXLFN” with k = 3.

[OR] Original practice question · Difficulty: Easy

562. Classify each as physical, procedural/administrative or technical control, and say which way of dealing with harm it mainly represents: (1) CCTV camera, (2) password-complexity policy, (3) disk encryption, (4) nightly offsite backup, (5) honeypot server.

[OR] Original practice question · Difficulty: Medium

563. Describe the four aspects used to study malicious-code infections and give two user countermeasures.

[OR] Original practice question · Difficulty: Easy